MammothDP: Private Boosted Decision Trees Ready for Trusted Hardware and Leakage-free Hyperparameters

Moritz Kirschte*, Thorsten Peinemann*, Kari Kostiainen†,
Jan Wichelmann*, Thomas Eisenbarth*, and Esfandiar Mohammadi*
*University of Luebeck
Lübeck, Germany
{m.kirschte, t.peinemann, j.wichelmann, thomas.eisenbarth, esfandiar.mohammadi}@uni-luebeck.de
†ETH Zurich
Zurich, Switzerland
kari.kostiainen@inf.ethz.ch

arXiv:2611.14317v1 [cs.CR] 10 Nov 2026

***Abstract*—Data spaces like the European Health Data Space (EHDS) require the protection of sensitive data in studies during the data's processing and the study's release alike. In this work, we investigate how to implement this mandate using established trusted execution environments (TEEs) and timing side-channel hardening to protect the processing even under a compromised server, and the state-of-the-art differential privacy (DP) notion to protect the release of studies on tabular data. This combined setup could seem to complete the picture, but in fact raises unexpected security challenges that we mitigate by introducing MammothDP: a significant milestone towards a holistic machine learning system based on the recent gradient boosted decision tree learner S-BDT that is provably DP if used within a privacy filter, timing side-channel hardened, and deployed on a TEE. To achieve a strong privacy-utility tradeoff, we introduce two novel components: an early stopping criterion that adaptively selects the number of trees without any privacy overhead, and an improved rollback protection that is no longer vulnerable under timing side-channel attacks.**

1. Introduction

Data spaces [1] are starting to be adapted on a larger scale, e.g., at the EU level [2] with the European Health Data Space (EHDS) [3] serving as a prominent example. Besides classical goals like high data utility or low computational overhead, security and privacy of data are stressed as an important data management challenge in data spaces [4]. This view is reflected in the EHDS regulation that mandates that studies on raw sensitive data should be processed inside a so-called *secure processing environment* [3, Art 73] and then released in an *anonymized format* [3, Art 66(2)].

In this work, we investigate how to implement this mandate, i.e., how a data space can be designed that protects the data's *processing* and study's *release* alike. As a technical backbone, we use the established trusted execution environment (TEE) [5], [6] and timing side-channel hardening [7]–[10] to protect the *processing* even under a compromised server, and the state-of-the-art differential privacy (DP) notion [11] to protect the *release* of studies on tabular data.[1] Based on the mandate and available technical solutions, we derive the following (strict) threat model:

Data Space Threat Model. The attacker's goal is to infer which of two neighboring datasets D, D' was used to release the study. To deploy a DP mechanism inside a TEE, we need to assume an attacker who (i) has the background knowledge to supply the release with D, D' (*typical DP assumption*), (ii) does not know what is processed inside the TEE but can rollback processes (*typical TEE assumption*), and (iii) exploits data-dependent timing differences at the binary code level, including control flow and memory access (*many typical timing side-channel attacks*).

Problem Statement & Approach. Deploying a system within this threat model that combines a *processing* solution (TEE & timing side-channel hardening) with a *release* solution (DP) could seem to complete the picture, but in fact, raises unexpected security challenges that are pointed out in Section 1.1 and go beyond the established constant-time programming and rollback protection [12]–[17]. Deploying a system that mitigates these challenges can finally comply with our threat model but does not automatically imply a strong privacy-utility tradeoff. In fact, we point out in Section 1.1 one major privacy-utility hurdle: common DP hyperparameter tuning is too privacy-costly.

We mitigate these security challenges and the privacy-utility hurdle with *MammothDP*: a significant milestone towards a holistic machine learning system for tabular data that is provably DP if used within a privacy filter [18]–[20], timing side-channel hardened, deployed on a TEE, and tunes

The research received funding from the BMFTR in the AnoMed project. Funded by the European Union – NextGenerationEU.

1. Other system setups are also plausible, like replacing TEEs with multi-party computation (MPC). Due to MPC's considerably high computational and communication overhead, we opt for a TEE-based DP setup as we find it more realistic and discuss an MPC-based approach in Appendix A.

hyperparameters without excess privacy costs. To achieve a strong privacy-utility tradeoff, we use novel components highlighted in Section 1.2 ("Our Contributions").

1.1. Detailed Problem Statement: Security Challenges of MammothDP

Releasing a study within a data space can come in many notions. *MammothDP* focuses on releasing a gradient boosted decision tree (GBDT) ensemble, which fits for the following reasons: i) GBDTs are a common technique to learn features from data, ii) the recent DP variant of a GBDT learner *S-BDT* [21] exhibits a strong utility-privacy tradeoff (incl. $\varepsilon \leq 0.1$) that fits our strict threat model, and iii) GBDTs offer two properties useful to address challenge P4: a strong theoretical basis and iterative training.

P1: DP Guarantees Deplete under Timing Side-channel Leakage. A DP training algorithm [11] ensures that an attacker can only deduce with a bounded probability from the output whether any particular data point was a member of the training. However, DP only bounds the privacy leakage of the output, not of the processing steps, such as timing leakage. As a consequence for MammothDP, although DP training algorithms like S-BDT [21] reach strong privacy guarantees (i.e., $\varepsilon \leq 0.1$), these guarantees become meaningless in a deployed system if it is easier for an attacker to deduce the membership of a data point not from the output of the model but by compromising the security guarantees that the TEE is supposed to provide. Figure 1 illustrates a simple timing attack in which simply observing the runtime, which an adversary could measure in a TEE setup, allows the adversary to completely erode a strong $\varepsilon = 0.1$ DP guarantee. More timing attacks are presented in the literature [22], [23] which also specifically target DP [24], [25].

Challenge P1

Timing side-channels can break the DP guarantee.

Our Solution

For *MammothDP*, we implemented a constant-time version of S-BDT and verified the robustness of the compiled binary against system-level attackers.

P2: DP's Threat Model Incompatible With Timing Side-channel Hardening. Classical timing side-channel hardening counters timing attacks by ensuring that control flow, memory access patterns, and instruction runtimes are the same for all input datasets. In a crypto context, FACCT [28] has shown that sampling noise, which is required for DP, though probabilistic, can also be constant-time. However, within the threat model of DP, timing side-channel hardening faces a new security challenge: *differing dataset sizes*.

DP hides from an attacker whether an n-sized dataset D or a $(n+1)$-sized dataset D' was used for model training.

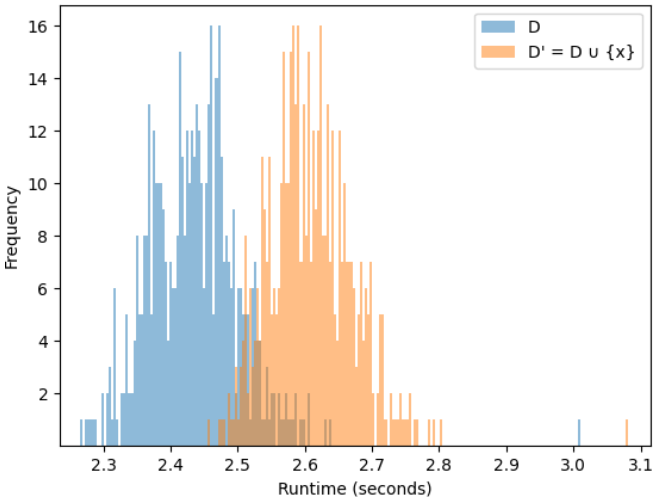


Figure 1: **Simplified timing attack on S-BDT: A single training point measurably impacts the runtime, although ($\varepsilon = 0.1$)-DP holds**: the adversarial advantage is TPR=0.29@FPR=0.002 at threshold $\tau = 2.64$ s. Setup: 500 S-BDT models with $T = 30{,}000$ trees of depth $d = 8$ are each trained on a random subset D of size 3 of Abalone [26] and similarly for D'. The metric TPR@FPR=0.002 quantifies the true positive rate (TPR) at a very low false positive rate (FPR) [27].

Per definition of DP, the attacker can choose the neighboring datasets D, D'. Thus, a successful timing side-channel hardening has to ensure that the runtime of D and D' is always the same. Provably, such a side-channel hardening is impossible for many ML algorithms: training a model on D' will in expectation always take longer than training on D as the training algorithm has to loop over one additional data point.

A simple solution like padding the dataset to a fixed size introduces not only considerable overhead but still fails since an attacker can just choose a dataset with twice that size. Another solution is to just exchange the DP definition to bounded DP where neighboring datasets are of the same size. However, the leakage does not go away if we just exchange the privacy definition and remove the capability of the attacker to probe with differing dataset sizes.

Challenge P2

No system can fully prevent timing side-channel leakage in the DP threat model.

Our Solution

For *MammothDP*, we upper-bound the timing leakage that occurs if S-BDT runs on D versus D' and prove so-called timing privacy [29].

P3: Rollback Attacks on TEEs Erode DP Guarantees and the Previous Defense *ElephantDP* Fails in our Threat Model, i.e. under Timing Side-channel Attacks. TEEs

guarantee data confidentiality and execution integrity. However, a TEE does not guarantee state continuity and is thus vulnerable to so-called rollback attacks [12], [13] that revert the TEE's persistent state to a previous version. In our threat model, these attacks seriously erode the DP guarantee [17]: after reverting the TEE, the TEE reruns the same DP query but with freshly drawn noise, which allows an adversary to erode the DP guarantee by averaging out the noise.

The state-of-the-art *ElephantDP* [17] protects against rollback attacks, but only in the absence of timing side-channel attacks. In fact, they choose a design that fails under timing side-channel attacks, as they limit the release and not the computation of a query. Thus, an adversary can use a rollback attack to rerun the DP query multiple times and observe the runtime to accumulate timing leakage (cf. Figure 1), which erodes the DP guarantee (cf. P1 & P2).

Challenge P3

The state-of-the-art rollback protection *ElephantDP* relies on a design that is vulnerable in our threat model, i.e., under timing side-channel attacks.

Our Solution

We propose a new design that mitigates such attacks by limiting the computation and not the release.

P4: Common DP Hyperparameter-tuning is too costly in terms of ε for S-BDT's Strict Privacy Guarantees ($\varepsilon \leq 0.1$). For deployment, a challenge in our MammothDP system that even occurs without the TEE threat model is that outliers can noticeably influence the selection of hyperparameters [30] and can thus leak privacy. A common technique for privacy-preserving hyperparameter tuning is to try out numerous hyperparameters and select the best one, e.g., via differentially private voting. Such methods increase the leakage by a factor of 2 to 3 in terms of ε [31]. As we aim for strict privacy guarantees ($\varepsilon \leq 0.1$), these DP hyperparameter selection methods are prohibitively expensive. Other techniques solely rely on heuristics by choosing hyperparameters that turn out to work well but fail to adapt to the particular training task.

Challenge P4

Prior DP hyperparameter tuning methods are too expensive for recent designs like S-BDT that target strict privacy guarantees ($\varepsilon \leq 0.1$).

Our Solution

We propose a new paradigm that combines two extremes: it not only costs no extra privacy but also remains adaptive to the learning task. For that, we only process intermediary-released noisy gradients (post-processing) to adaptively decide at each iteration whether to stop the training early.

1.2. Our Contributions

We introduce *MammothDP*: a significant milestone towards a holistic TEE-based system of a timing side-channel hardened DP tree ensemble learner based on S-BDT with leakage-free adaptive hyperparameters and improved rollback protection. *MammothDP* addresses all problems (P1-P4) from the problem statement as follows:

(P1 & P2) We provide a constant-time implementation of S-BDT[2] that is hardened against timing leakage due to
- differing memory access patterns and control flow via adapting S-BDT to use bitmasking and to ensure that we always loop across all data points,
- differing runtime of instructions via tailoring the C++ library *libfixedtimefixedpoint* [32] to S-BDT,
- differing noise sample runtimes via tailoring FACCT [28] to the Gaussian and Bernoulli noise in S-BDT, and
- differing data sizes within the threat model DP that lead to a differing number of loop iterations (and show so-called timing privacy [29]).

We validate our constant-time results using Microwalk [33] and measure the computation overhead.

(P3) We identify that the state-of-the-art rollback protection ElephantDP [17] is flawed in our threat model, i.e., under timing side-channel attacks. For MammothDP, we propose and evaluate a new design that mitigates such attacks by limiting the computation and not the release. Our new design is realized by adapting Memoir [12] who use hash chains as a freshness tag.

(P4) We introduce a novel early tree stopping technique for S-BDT that has leakage-free yet adaptively-selected hyperparameters at no extra privacy budget. For that, we only process intermediary-released noisy gradients (post-processing) to decide at each training iteration whether to stop the training early. Privacy-wise, our early stopping provably bounds the Rényi divergence and is, hence, compatible with provable DP bounds when used within a privacy filter. Utility-wise, we design our early stopping such that it triggers if we detect a possible point of bias-freeness. This insight is based on our theoretical foundation for regression based on the well-known division of the mean squared error (MSE) into bias and variance error, with the goal of minimizing the bias. We experimentally show that we still perform worse than S-BDT with privacy-leaky optimal hyperparameters but

2. https://github.com/kirschte/MammothDP/tree/main/tee-ready-image

significantly outperform S-BDT with a statically chosen number of trees, especially for regression.

Structure. Sections 4, 5 and 6 cover our contributions addressing P1 & P2, P3, and P4 respectively. Our evaluation is in Section 7.

2. Related Work

TEE Rollback Protection. Many rollback protections exist [12]–[16] with different state continuity modules (SCM), based on TPMs or distributed state-keeping systems. MammothDP and the recent ElephantDP [17] abstract from a concrete SCM and focus on rollback protection within a DP attack model. However, ElephantDP ultimately relies on a design that is vulnerable in our threat model, i.e., under timing side-channel attacks. We discuss this limitation and how to build a better design in Section 5.

DP-ML With Leakage-Free Hyperparameters. Current work mainly focuses on finding the best hyperparameter from a previously specified set of hyperparameter choices. In that, there are three approaches for leakage-free hyperparameters: via heuristics [34], [35], via separating the data into disjoint sets [36], [37], or via spending extra privacy [30], [31], [34], [38]. Heuristics are not adaptive to the training progress. Spending extra privacy budget leads to a worse privacy-utility tradeoff. Dividing the dataset into disjoint sets implies using less data in training, which deteriorates the utility. In this work, we chose a new paradigm that combines two extremes: it not only costs no extra privacy but goes one step beyond a heuristic by remaining adaptive to the learning task. For that, we reuse intermediary noisy gradients that the S-BDT training releases anyway (post-processing). Although it provably has a bounded privacy budget at each step, it adds additional complexity with the privacy filter to also reach provable DP bounds.

Hardening ML Algorithms for Trusted Hardware. Prior works harden various machine learning algorithms against timing side-channels for trusted hardware. Law et al. [9] harden the XGBoost [39] algorithm against cache side-channels; Ohrimenko et al. [10] propose constant-time implementations for various ML algorithms, including decision trees and support vector machines. Sasy and Ohrimenko [40] propose data-oblivious subsampling that touches a subsample of size B in $\Theta(B)$ rather than $\Theta(n)$ for a full scan. However, S-BDT still requires gradients and Hessians for all n data points each round for individual privacy accounting. We therefore opt for easily verifiable linear scans (cf. Section 4.1), especially as training a tree on 10^6 points only takes ≈ 8 seconds.

3. Preliminaries

3.1. Differential Privacy (DP)

DP [11] is the de facto standard for provable privacy. Given a mechanism that has a data-dependent output, DP requires that the impact of a single data point on the output is limited and thus deniable. In line with S-BDT [21], we consider the DP variant Rényi DP (RDP) in the unbounded definition, where the effect of adding or removing a single instance from a dataset on the output is analyzed.

Definition 1 (Differential Privacy [11])**.** Let $2^{\mathcal{X}}$ be the set of all datasets over the universe of all rows $\mathcal{X}$, $\mathcal{R} \coloneqq \mathrm{RV}(X)$ be the set of all random variables over a given X, and $X \sim X'$ be two neighboring datasets where $X, X' \subseteq \mathcal{X}$ and $X' \coloneqq X \cup \{x\}$ for some $x \in \mathcal{X}$.
Given $\varepsilon \geq 0$ and $\delta \in [0, 1]$, a randomized algorithm $\mathcal{M} \colon 2^{\mathcal{X}} \to \mathcal{R}$ satisfies (ε, δ)-DP if, for any two neighboring datasets $X \sim X'$ and any $S \subseteq Y$: $\Pr[M(X) \in S] \leq e^{\varepsilon} \cdot \Pr[M(X') \in S] + \delta$.

Definition 2 (Rényi Divergence [41])**.** Given probability distributions P, Q over $\mathcal{R}$ where $P(o)$ denotes the density of P at o, the Rényi divergence of order α is $\mathrm{D}_\alpha(P \parallel Q) \coloneqq \frac{1}{\alpha-1} \log \mathrm{E}_{o \sim Q}(\frac{P(o)}{Q(o)})^\alpha$.

Definition 3 (Rényi DP [42, Def. 4])**.** A randomized mechanism $M \colon \mathcal{X} \mapsto \mathcal{R}$ satisfies $(\alpha, \rho(\alpha))$-RDP if for any neighboring datasets X, X': $\mathrm{D}_\alpha(M(X) \parallel M(X')) \leq \rho(\alpha)$.

With RDP, we can mathematically describe features like composition, filters [19], or subsampling [43] and can convert it back to DP (cf. Appendix B.3). An important property of (R)DP is *post-processing*: only working on the output of an (R)DP-mechanism does not increase the leakage.

Lemma 4 (Postprocessing, [42, Sec. 3])**.** *Given a randomized mechanism M and a randomized function $f \colon \mathcal{R} \to \mathcal{R}'$. If M is $(\alpha, \rho(\alpha))$-RDP, then $f \circ M$ is also $(\alpha, \rho(\alpha))$-RDP.*

3.2. Gradient Boosted Decision Trees (GBDT)

GBDTs [44] learn a sequence of decision trees $f \coloneqq (f^{(1)}, \ldots, f^{(T)})$ by iteratively correcting errors of prior trees. Let $X = \{(x_1, y_1), \ldots, (x_n, y_n)\} \subseteq \mathbb{R}^m \times \mathbb{R}$ denote a labeled dataset with n data points and m features. For simplicity, we denote y as a label, although a regression target applies equally. A tree ensemble f minimizes

$$\mathcal{L}^{(T)}(f, X) = \textstyle\sum_{(x_i, y_i) \in X} l(\phi_f^{(T)}(x_i), y_i) + \sum_{t=1}^{T} \Omega(f^{(t)}) \tag{1}$$

where l is a twice-differentiable convex loss function, e.g., squared error or binary cross-entropy, and $\Omega(f^{(t)}) = {}^1\!/_2 \lambda \|V^{(t)}\|^2$ is a regularization term on the vector of leaves $V^{(t)} = \mathrm{Leaves}(f^{(t)})$.

The ensemble prediction of a data point x is

$$\tilde{y}^{(T)} \coloneqq \phi_f^{(T)}(x) = f^{(0)} + \eta \textstyle\sum_{t=1}^{T} f^{(t)}(x) \tag{2}$$

which sums the prediction of each tree $f^{(t)}(x)$ scaled by learning rate η and the init score $f^{(0)}$ which is constant for all x. Optionally, $f^{(t)}(x)$ is also clipped between $-\beta$ and β.

Each tree $f^{(t)}$ recursively predicts from a root node to the leaves: Each node has a split criterion that decides, based

on the attributes of a data point x, whether the prediction of x should continue with the left or right child. This process is repeated recursively until the maximal tree depth is reached. Then, the value of the leaf where x landed, i.e., $f_j^{(t)}(x)$, is returned as the prediction. The ensemble prediction is then a learning-rate-weighted sum of tree predictions.

For training, we consider a variant of GBDTs that chooses their split criterion uniformly at random [45] and only trains each leaf value. For that, the learner XGBoost [39] proposes Newton boosting, a second-order approximation of the loss function with gradient $g(\tilde{y}_i, y_i) = \partial/\partial\tilde{y}_i l(\tilde{y}_i, y_i)$ and Hessian $h(\tilde{y}_i, y_i) = \partial^2/\partial\tilde{y}_i^2 l(\tilde{y}_i, y_i)$:

$$l(\tilde{y}_i^{(t)}, y_i) = l(\tilde{y}_i^{(t-1)} + f^{(t)}(x_i), y_i) \approx l(\tilde{y}_i^{(t-1)}, y_i) + g(\tilde{y}_i^{(t)}, y_i) f^{(t)}(x_i) + \tfrac{1}{2} h(\tilde{y}_i^{(t)}, y_i) {f^{(t)}}^2(x_i). \quad (3)$$

The leave value $f_j^{(t)}$ is derived with the Newton method as:

$$f_j^{(t)}(x) = V_j^{(t)}(x) = -\frac{\sum_{(x_i,y_i)\in I_{\text{Leaf}_j}^{(\text{train})}} g(\phi_f^{(t)}(x_i), y_i)}{\sum_{(x_i,y_i)\in I_{\text{Leaf}_j}^{(\text{train})}} h(\phi_f^{(t)}(x_i), y_i) + \lambda} \quad (4)$$

for any train data point $x \in I_{\text{Leaf}_j}^{(\text{train})}$ landing in the j-th leaf $V_j^{(t)}$.

Algorithm 1: Training skeleton of S-BDT.

Input: T: number of rounds, D: training data

$f = (f^{(0)})$; `// ensemble incl. init score`
for $t = 1$ **to** T **do** `// train tree` $f^{(t)}$
  $f^{(t)} =$ `RandomBinaryTree(...)`;
  $D =$ `PrivacyFilter(`D`,...)`;
  $S =$ `PoissonSubsample(`D`,...)`;
  $\forall j$: $I_{\text{Leaf}_j}^{(\text{train})} = []$; `// initialize leaf array`
  for each *sample* (x_i, y_i) **in** S **do**
    $\hat{y}_i =$ `PredictEnsemble(`f, x_i`)`; `// Alg 2`
    $g_i = g(\hat{y}_i, y_i)$; `// gradient of loss` l
    $h_i = h(\hat{y}_i, y_i)$; `// Hessian of loss` l
    $v_i = f^{(t)}$.root;
    while v_i **is not** *a leaf* **do**
      `// find leaf of` x_i
      if v_i.*split_criterion*(x_i) **then** $v_i = v_i$.child.left ;
      else $v_i = v_i$.child.right ;
    Append x to $I_{\text{Leaf}_j}^{(\text{train})}$ via $j =$ `LeafIndexOf` (v_i);
  for each *leaf* v_j **in** $f^{(t)}$ **do**
    `// cf. Equation (4) with DP`
    $f_j^{(t)}(\cdot) \coloneqq \frac{\tilde{g}_j^{(t)}}{\tilde{h}_j^{(t)}} = \frac{\texttt{NoisyClipGradSum}(I_{Leaf_j}^{(train)})}{\texttt{NoisyClipHessSum}(I_{Leaf_j}^{(train)})}$;
  Append tree $f^{(t)}$ to ensemble f;
return f;

3.2.1. S-BDT. The state-of-the-art S-BDT [21] is a GBDT learner that is $(\alpha, \rho(\alpha))$-RDP by choosing the splits uniformly at random and adding Gaussian noise to the leaves, i.e., to a clipped Hessian and a clipped gradient sum. Algorithms 1 and 2 are skeletons of S-BDT training and prediction with the full pseudocode of our constant-time S-BDT in Appendix F.

Algorithm 2: Prediction skeleton of S-BDT.

Input: x: data point, f: S-BDT ensemble, η: learning rate

$\hat{y} = f^{(0)}$;
for $t = 1$ **to** `Length(`f`)` $- 1$ **do**
  $v = f^{(t)}$.root;
  while v **is not** *a leaf* **do** `// find leaf of` x
    if v.*split_criterion*(x) **then** $v = v$.child.left ;
    else $v = v$.child.right ;
  $\hat{y} = \hat{y} + \eta \cdot f_j^{(t)}(x)$ with $j =$ `LeafIndexOf(`v`)`;
return $\hat{y}$; `// cf. Equation (2)`

3.3. Trusted Execution Environment (TEE)

TEE architectures such as Intel SGX [46] and Arm TrustZone [47] offer so-called *enclaves* that are designed to isolate applications from the rest of the system, including the untrusted OS. Intel TDX [48], AMD SEV [6], and Arm CCA [49] isolate entire virtual machines (VMs) from any untrusted code running on the same physical computing platform. All such TEEs have the same high-level goal: to allow confidential workloads to be executed on a computing platform that is trusted as little as possible (e.g., the OS, hypervisor, or administrator can be malicious).

Most TEEs offer an isolated execution environment using memory encryption. In the case of Intel's SGX, the processor keeps track of the currently executing code and allows confidential data to be accessed only when the correct enclave is running. TEEs enable the processing of sensitive data even if the adversary controls the rest of the computing platform (data confidentiality). TEEs also allow third parties, such as data owners, to verify that the expected code is running inside the TEE before provisioning sensitive data to it (execution integrity). These guarantees provide an attractive alternative to secure computation using cryptography, as TEEs can process confidential data efficiently in plaintext without the need for a trusted party [50].

4. Constant-time S-BDT (P1 & P2)

Deploying S-BDT inside a TEE does not suffice to protect its processing: timing side-channel attacks can still leak information via data-dependent timing behavior. These attacks exploit shared hardware features like caches [51]–[56] and branch prediction units [57], [58], leak information to a malicious hypervisor using the page table [59], [60] or track a TEE's control flow using other microarchitectural resources via single-stepping [22], [23].

The most widely used timing side-channel protection is software hardening via constant-time programming [7]–[10] that ensures no data-dependent behavior on the architectural

Algorithm 3: Bitmasked subsample sum.

Input: D: dataset

```
Bitmask = PoissonSubsample(D, ...);
for each sample s in D do
    ...
    Append s.gradient·Bitmask(s) to v.gradients;
    Append s.hessian·Bitmask(s) to v.hessians;
```

execution-trace layer, i.e., no data-dependent memory access or control flow, assuming the processor introduces no additional timing leakage for a small subset of operations. In this work, we additionally protect against differing program runtime by proving so-called Timing DP, and remove operand-dependent instruction runtime. In this section, we briefly describe each timing side-channel and our mitigation.

4.1. Data-dependent Memory Access

Attack. Among many attacks that target cache side-channels [52]–[56], we highlight an example attack based on the Prime+Probe cache monitoring technique [61] which was improved to allow server operators to attack TEEs [51]. First, the attacker *primes* the cache, i.e., accesses memory such that the entire cache is filled with data of the attacker process. The victim then executes code with access to memory addresses depending on sensitive data. The attacker *probes* which of their cache lines got evicted, telling them which of the memory addresses the victim accessed and, therefore, leaking information about sensitive data.

Leaky Components in S-BDT. The vanilla implementation of S-BDT does not hide the patterns of which data points are accessed in memory. It leaks for each data point the leaf that the data point belongs to, which depends on the public split criteria of the tree and the data point's sensitive attributes. As a consequence, this reveals the data point's specific attributes, or at least an imprecise range for those attributes. Memory access only to data points with leftover privacy budget reveals data points that still have per-data-point privacy budget, disallowed in individual privacy accounting [19]. Accessing only a training round's subsample is disallowed in privacy amplification by subsampling [43], because that assumes that the subsample remains hidden from an attacker.

Our Mitigation. Our constant-time implementation loops over all training data points in a fixed order, independent of whether they belong to a given leaf, independent of the remaining individual privacy budget, or subsample inclusion. Thus, each data point is always loaded from memory for computations on sensitive data. We use bitmasks to mask out data points (cf. Algorithm 3, changes from S-BDT highlighted) that should not contribute to the result of a computation because they are not in the current subsample, have no privacy budget, or do not belong to a given leaf.

Efficiency. Scanning all n data points costs $\Theta(n)$ per tree instead of $\Theta(B)$ for a subsample of size $B \approx \gamma \cdot n$ ($\gamma \leq 0.5$). Data-oblivious subsampling [40] touches a subsample of size B in $\Theta(B)$ rather than $\Theta(n)$ for a full scan. However, S-BDT still requires gradients and Hessians for all n data points each round for individual privacy accounting. We therefore opt for easily verifiable linear scans (cf. Section 4.1), especially as training a tree on 10^6 points only takes ≈ 8 seconds.

4.2. Data-dependent Control Flow

Attack. Single-stepping [22], [23] allows a server operator to precisely track the control flow of a TEE by sending hardware interrupts. These interrupts are served *after* the currently executing instruction has completed, and take a variable amount of time depending on the instruction type and the microarchitectural state of the processor. This allows differentiating between program branches.

Leaky Components in S-BDT. Vanilla S-BDT's tree prediction evaluates the path from the tree root to the leaf reached by a data point, and an attacker can track this path and leaf by single-stepping. The particular leaf of a data point can leak sensitive information (cf. Section 4.1).

Our Mitigation. Our constant-time version traverses the entire tree in a fixed order, independent of the data point. Instead of branching in traversal, we compute every split criterion in the entire tree and use a constant-time selection procedure (cf. Algorithm 4) to select the correct leaf value.

Algorithm 4: Constant-time prediction (call with root node).

```
PredictTree(node v, data point x):
    if v is leaf then
        return prediction of v;
    l = PredictTree(v.child.left, x) ;
    r = PredictTree(v.child.right, x) ;
    return v.split_criterion(x) · l + (1 − v.split_criterion(x)) · r
```

4.3. Data-dependent Runtime of Instructions

Attack. Due to the complexity of floating-point numbers, modern processors can struggle to handle certain inputs efficiently and runtime measurements become a side-channel. For example, for subnormal operands, i.e., ones close to zero, multiplication can exceed 200 clock cycles on an Intel Core i7 processor, but takes 4 cycles for normal operands [32].

Leaky Components in S-BDT. S-BDT repeatedly performs operations on sensitive gradients and Hessians or bitmasks used for masking out data not in a subsample.

Our Mitigation. We avoid ordinary instructions whenever an operand is sensitive. Instead, we use constant-time equivalents from the libftfp [32] math library for the affected instructions. libftfp ensures to execute every code path, produce every intermediary result instead of returning results early, use no data-dependent branching, loop with a fixed number of iterations, and use only basic integer operations that are expected to be constant-time.

4.4. Leaking Noise Samples

Attack. Standard noise samplers often have timing side-channels. Samplers based on randomized trees, branch over the tree to then select a random sample from a leaf, thus leaking the branch decisions (e.g. by single-stepping, cf. Section 4.2) leaks the random sample [62]. Samplers based on lookup-tables access memory of lookup-table entries that are used to generate the random sample, therefore leaking the memory access patterns (e.g. via cache attacks, cf. Section 4.1) can leak information about the random sample [63].

Leaky Components in S-BDT. S-BDT uses randomness at three stages: two times Laplace noise to noise its DP initial score, multiple times Gaussian noise to noise the leaf values, and privacy amplification by Poisson subsampling uses Bernoulli noise to decide the inclusion of a data point in a training round.

An attacker who is able to leak the Gaussian or Laplace noise samples can denoise a DP release. Privacy amplification by Poisson subsampling assumes the subsample remains hidden [43]; thus, leaking the randomness that determined the subsample negates the privacy amplification.

Our Mitigation. We replace S-BDT's Gaussian and Laplace samplers with FACCT [28] (detailed in Appendix B.2), a constant-time sampler for the discrete Gaussian D_σ over the integers, and use X/σ with $X \sim D_\sigma$, $\sigma = 2048$, in place of a standard normal sample. On a target machine with finite precision, every implementable Gaussian sampler outputs values on a grid, and the best achievable distribution is $\mathcal{N}(0,1)$ rounded to that grid. As σ grows, this rounded continuous Gaussian and our rescaled discrete Gaussian become statistically closer. In other words, our sampler approaches the limit of "continuity" that the finite precision allows, as does any real-world implementation of a continuous sampler.

We replace the Bernoulli sampler for Poisson subsampling with the constant-time implementation of FACCT [28].

Implications. Replacing Laplace noise with Gaussian noise in S-BDT's DP initial score yields the Gaussian mechanism instead of the Laplace mechanism; consequently, those releases satisfy approximate DP rather than pure DP, and we account for this δ accordingly. On the regression dataset *Abalone* with small ε, constant-time S-BDT shows a slight RMSE decrease over the vanilla version, due to the replacement. Since the initial score is only activated for regression, this impact is limited to the regression dataset.

For DP algorithms that use continuous noise distributions, the implication of running a DP algorithm on a real system with fixed precision is often abstracted away in the literature, and we are aware of the weaknesses.

4.5. Leaking Input Length

Attack. In unbounded DP, neighboring datasets differ by exactly one data point. If the training runtime depends on the number of data points, an untrusted server operator observing the training runtime can distinguish the input lengths, revealing which dataset was processed and eroding the DP guarantee. Simple input padding to a fixed size does not suffice, since the attacker can choose a dataset that is much larger than that size.

Leaky Components in S-BDT. Since vanilla S-BDT loops over the data points, its runtime can reveal the number of data points.

Our Mitigation. We make the observable runtime depend only on a DP release of the input length. For input length l we compute a noisy input length $\hat{l} = l + Z + 2 \cdot \sigma_{\text{input}}$, $Z \sim \mathcal{N}(0, \sigma^2_{\text{input}})$, and then pad data with random placeholder data, or truncate if necessary (cf. Algorithm 5), i.e. remove data points. We add a slack of $2 \cdot \sigma_{\text{input}}$ to likely avoid truncation. Afterwards, all S-BDT loops use the noisy length l', so runtime observations reveal at most l', rather than the exact input length l. Data owners perform this padding or truncation before the server executes S-BDT, and the server masks out placeholder data using bitmasks (cf. Section 4.1).

For ease of analysis, we excluded an extra (ε, δ) from our experiments because the noisy input length costs computation but no utility, as an inaccurate input length only means looping over extra placeholder data, and the privacy cost stays tiny. For $(\varepsilon, \delta) = (0.001, 10^{-11})$, a Gaussian with $\sigma_{\text{input}} = 5013$ suffices and $\pm 5{,}000$ iterations is negligible for datasets with $120{,}000$ points.

Algorithm 5: Noisy input length constant-time S-BDT .

Each data owners:
Input: D: dataset
1 $\tilde{l} = |D| + \mathcal{N}(0, \sigma^2_{\text{input}}) + 2 \cdot \sigma_{\text{input}}$;
2 Add $\tilde{l} - |D|$ placeholder data or remove data from D;
3 Generate `Bitmask` of placeholder data;
Server:
4 Collect data and `Bitmask` from data owners;
5 Run `Bitmask` masked constant-time S-BDT;

4.5.1. Timing Privacy.

We prove so-called Timing Privacy [29] in an idealized RAM model to validate our construction of Algorithm 5. Intuitively, Timing Privacy demands the randomized running time of a mechanism not to leak much more than what is already revealed by the output distribution. The formal definition of Timing Privacy, the formal statement, and our proof are given in Appendix E.

5. Improved TEE Rollback Protection (P3)

Rollback attacks present a severe and practical threat to TEE-based DP systems that run on untrusted computing platforms, such as cloud environments. Such systems only guarantee DP properties if *(a)* any output released by the TEE is the result of a differentially private computation and *(b)* the TEE has correctly enforced that there was sufficient *privacy budget* available for the requested computation. In a simple rollback attack, the adversary requests the TEE to

perform a DP computation. The TEE implementation checks that it has sufficient privacy budget, performs the computation, updates the remaining budget, seals its sensitive data and updated budget, and releases the computation result. In sealing, the TEE architecture derives an encryption key that is specific to each TEE application, which can then encrypt, decrypt, and authenticate data that it needs to store externally. After that, the adversary controlling the untrusted server requests the TEE to perform another DP computation, but instead of providing the latest seal to the TEE, it provides a previous version, which allows the adversary to reuse the privacy budget and thus violate DP guarantees.

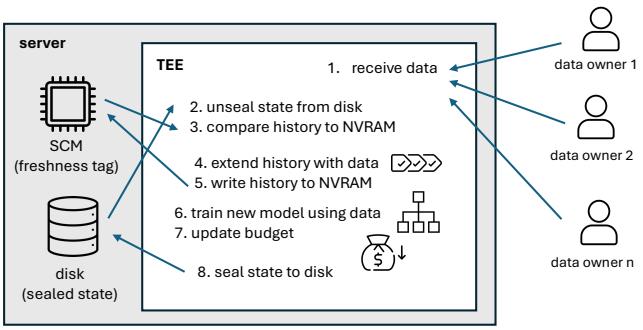


Figure 2: Overview of our rollback protection solution.

5.1. Rollback Protection Requirements

We argue that a *secure* and *practical* rollback protection solution should meet the following four requirements.

R1: Budget Integrity. The main requirement is privacy budget integrity. The TEE implementation, realizing the DP algorithm, must always perform the mandatory privacy budget check using the correct (latest) budget value. This requires that the TEE implementation must only accept the latest sealed data when restoring its persistent state at the beginning of a new TEE execution.

R2: Crash Tolerance. Another common requirement for rollback protection is crash tolerance. After an unexpected crash, the TEE implementation should be restartable, and it can continue answering DP computation requests. In particular, the way the freshness-tag check is implemented should not introduce deadlocks. We note that more general availability guarantees are typically not possible for TEE systems where the adversary, who controls the untrusted computing platform, can start and stop TEE executions freely, and thus trivially prevent any TEE execution.

R3: Timing Side-channel Minimization. Execution in modern TEE architectures is known to produce *timing side-channel traces* that the adversary can use to infer secrets, such as sensitive training data. The TEE implementation should ensure that the adversary *cannot* collect timing side-channel traces beyond the legitimate algorithm executions permitted by the privacy budget. We consider such side-channel minimization a complementary protection to TEE implementation hardening described in Section 4.

R4: Compatibility. Finally, we argue that the rollback protection solution should be compatible with various state continuity modules. In particular, the rollback protection solution should work with both standard security chips, such as TPMs, and custom distributed state-keeping systems (e.g., research proposals like [14], [15]).

5.2. Limitations of Prior Work

ElephantDP [17] is a state-of-the-art rollback protection system for DP algorithms. Its design works as follows: when the TEE is started, it loads its persistent state from disk and compares a counter value used as the freshness tag to the SCM content. To evaluate a requested DP computation, the TEE implementation first checks that there is sufficient privacy budget available, then executes the computation, and updates the remaining privacy budget. After that, the TEE implementation writes its updated persistent state to disk. The state contains the latest computation result, the updated privacy budget, the computation request, and an incremented execution counter. Finally, the TEE writes this state to SCM. The design assumes that the SCM implementation is able to enforce the following rule: The written counter value must be exactly one higher than the previous value stored in the SCM. Otherwise, it reports failure.

However, this approach does not minimize timing side-channels (**P3**): the adversary can request a DP computation, collect timing side-channel traces from its execution, kill the TEE before anything is saved on disk, and repeat this process. In effect, the design creates a *timing side-channel oracle* that the adversary can query with freely-chosen computation requests for an unlimited number of times. The root cause behind this problem is that, by updating the SCM after the DP computation, ElephantDP focuses on controlling the *release* of DP computation results from the TEE, but it does not limit the actual execution of DP computations.

ElephantDP's design has compatibility limitations (**P4**): their rollback protection solution requires an SCM that compares the written value to the currently stored value. While such checks can be implemented in custom distributed systems like [14], they are not available in all standard security chips like TPMs that support only a simple read and write interface to non-volatile memory (NVRAM).

5.3. Overview of Our Solution

We observe that the rollback protection requirements can be met by adapting a technique previously introduced by Parno et al. in a paper called Memoir [12]. Parno's main idea is to use a *hash chain* of all execution inputs as the freshness tag. This technique is compatible with various SCMs (**R4**) as it only requires a simple read and write interface. It also provides the basis for both budget integrity enforcement (**R1**) and crash tolerance (**R2**). To ensure timing side-channel minimization (**R3**), in the context of TEE-based DP implementations, new technical challenges must be solved.

An overview of our solution is shown in Figure 2. Here, we illustrate the training phase of an ML model, but note

that the model query phase would work similarly (data owners would be replaced by data analysts, training data would be replaced by queries, and model training would be replaced by model inference).

We initialize the system by collecting randomness from each data owner. During the first TEE execution, the TEE receives randomness shares from all the data owners and derives a pseudo-random seed based on the received shares. The TEE implementation then seals to disk its initial state, which contains the derived seed, an empty ML model, a full privacy budget value, and the value zero to represent an empty hash chain. The TEE also writes the zero value as a freshness tag to the SCM to complete the initialization.

Training iterations proceed as illustrated in Figure 2. (1) Data owners send new training data to the TEE that (2) unseals its persistent state from disk and (3) checks that a freshness tag (initially zero) included in the seal matches the value stored in the SCM. If these checks pass, (4) the TEE then extends the (initially empty) hash chain with the input (training) data and (5) writes the extended chain value to the SCM. Note that the freshness tag is advanced to the next value before the actual DP computation takes place. This is essential to prevent timing side-channel oracles. (6) The model training algorithm can now be executed using the input (training) data, and (7) the TEE will update the privacy budget accordingly. Finally, (8) the TEE seals its updated persistent state (including the trained model, updated budget, and extended hash chain as the freshness tag) to disk. At this point in the process, the persistent state also matches the previously advanced freshness tag. The TEE is now ready to be closed down and wait for its next execution.

Additionally, the solution includes a recovery routine that re-executes the previous input (and only that input) after a crash during DP algorithm execution. During recovery, the TEE reads the previous state seal from the disk, extends the hash chain with the same (latest) input data, and only proceeds with the DP computation if the extended hash chain value matches the SCM content.

5.3.1. Security Guarantees. Our approach preserves budget integrity (**R1**), because the TEE will only accept the latest seal or the previous seal with the same input. In both cases, the privacy budget is enforced correctly for the sensitive training data. This approach is also crash resilient (**R2**). If the DP algorithm execution crashes, we have a situation where the updated state seal is not created, and the previous state seal, still available on disk, no longer matches the extended hash chain (freshness tag) stored in the SCM. However, since the freshness tag is a deterministic hash chain, our recovery routine can safely allow the re-execution of the latest input and only that input.

This also minimizes timing side-channels (**R3**). As the freshness tag is updated and written to the SCM *before* the DP computation, the TEE implementation cannot serve as a timing side-channel oracle. The key difference to ElephantDP is that, in our solution, we focus on controlling DP computation inside the TEE, instead of controlling the release of DP computation results. To ensure that the re-executions of the latest input during the recovery routine do not benefit the adversary, we must carefully ensure that all the pseudorandom values used in the computation remain the same across executions. We achieve this by fixing the randomness seed during the first TEE execution. Furthermore, through code hardening (see Section 4), we ensure that there is no leakage from arithmetic operations and similar instructions known to exhibit microarchitectural leakage. Such protections are new to our rollback solution.

Finally, the approach is compliant (**R4**) with SCMs like TPMs that only support a simple read and write interface. We defer the details of our rollback protection design, its security analysis, and implementation notes to Appendix D.

6. Leakage-free Yet Adaptive Hyperparameters: Early Tree Stopping (P4)

A challenge in our MammothDP system that even occurs without a TEE is that outliers can noticeably influence the selection of hyperparameters [30] and can thus leak privacy. To solve this challenge, we propose a new paradigm that combines two extremes: it not only costs no extra privacy but also remains adaptive to the learning task. For that, we fix all hyperparameters except the number of trees t. During each training iteration, we now only process intermediary-released noisy gradients (post-processing) to adaptively decide whether to stop the training early.

We thus assume that the number of trees is the most important hyperparameter which can cover up other suboptimally chosen hyperparameters and illustrate that on two examples: i) Decreasing parameters like the subsampling rate γ or maximal tree depth d results in a weaker tree. If each tree gets weaker, we can cover that up by using more trees. ii) If we have a larger dataset, we can increase the number of trees to reach a similar signal-to-noise ratio.

Structure. In Section 6.1, we show that the leaf values of a regression tree can approximate the direction of the bias error as part of the MSE metric. In Section 6.2, we show EARLYSTOPPEDSBDT which stops the training early based on this insight that (noisy) leaf values can approximate the MSE error, and discuss its privacy implications in Section 6.3.

6.1. Theoretical Foundation for Regression

The mean squared error (MSE) is a common metric for regression predictors like GBDTs. For true label y and predicted label $\tilde{y}$, it is: $\mathrm{MSE}(y, \tilde{y}) = \frac{1}{n}\sum_{i=1}^{n}(y_i - \tilde{y}_i)^2$. If each error $e_i := y_i - \tilde{y}_i$ is an iid element of the error distribution $\mathcal{E}$, we can also write: $\mathrm{MSE}(\mathcal{E}) = \mathrm{E}[\mathcal{E}]^2$. The MSE consists of a bias part $\mathrm{E}[\mathcal{E}]$ and a variance part $\mathrm{Var}(\mathcal{E})$ due to the relation $\mathrm{E}[\mathcal{E}]^2 = \mathrm{Var}(\mathcal{E}) + (\mathrm{E}[\mathcal{E}])^2$ for a random variable $\mathcal{E}$. The bias error (underfitting) is mostly caused by a systematic error in the learning, whereas the variance error (overfitting) is mostly caused by non-deterministic behavior of data which is not perfectly predictable. Data frequently

consists of unlearnable white noise and a learnable correlated part, and as the white noise can not be fitted, variance error will remain. In contrast, the bias error can vanish if the correlated part is predicted well. Thus, a predictor that minimizes the bias is often also a good predictor with a small MSE.

As a proxy for stopping the tree training as soon as the bias is small, we determine the bias error difference quotient ∇B: a discretized gradient that indicates how the bias error changes with each new tree. Formally, we have $\nabla B = \sum_{i=1}^{n} e_i^{(t)} - \sum_{i=1}^{n} e_i^{(t-1)}$ with $e_i^{(t)} := y_i - \tilde{y}_i^{(t)}$ as the error term of the t-th tree on (test) input (x_i, y_i). If $\nabla B = 0$, we have an extremum (i.e., maximum, minimum, or saddle point) for the bias error. A saddle point is not stable and will likely vanish if we train until the $(t+1)$-th tree. A maximum or minimum indicates that the bias that is unsigned has grown/fallen during training and now reaches a saturation point. If we assume that we have a useful configuration and thus make progress during training, reaching the first extremum is a good heuristic that the bias might have reached a small value.

We simplify the bias error difference quotient ∇B:

$$\begin{aligned}\nabla B &= \textstyle\sum_{i=1}^{n} e_i^{(t)} - \sum_{i=1}^{n} e_i^{(t-1)} \\ &= \textstyle\sum_{i=1}^{n} y_i - \tilde{y}_i^{(t)} - \left(\sum_{i=1}^{n} y_i - \tilde{y}_i^{(t-1)}\right) \\ &= \textstyle\sum_{i=1}^{n} \tilde{y}_i^{(t)} - \tilde{y}_i^{(t-1)}\end{aligned}$$

by definition: $\tilde{y}_i^{(t)} = f^{(0)} + \eta \sum_{t'=1}^{t} f^{(t')}(x_i)$ (cf. Equation (2)) with $f^{(t')}(x_i)$ as the t'-th tree prediction on (test) input x_i

$$\begin{aligned}&= \eta \textstyle\sum_{i=1}^{n} \left(\sum_{t'=1}^{t} f^{(t')}(x_i) - \sum_{t'=1}^{t-1} f^{(t')}(x_i)\right) \\ &= \eta \textstyle\sum_{i=1}^{n} f^{(t)}(x_i). \end{aligned} \tag{5}$$

By definition of a leaf value $V_j^{(t)}(x)$ in Equation (4), we have for any data point $x \in I_{\text{Leaf}_j}$ that ended up in the j-th leaf $V_j^{(t)}$:

$$f_j^{(t)}(x) = V_j^{(t)}(x) = -\frac{\sum_{(x_i,y_i)\in I_{\text{Leaf}_j}^{(\text{train})}} g(\phi_f^{(t)}(x_i), y_i)}{\sum_{(x_i,y_i)\in I_{\text{Leaf}_j}^{(\text{train})}} h(\phi_f^{(t)}(x_i), y_i) + \lambda}. \tag{6}$$

As an approximation, we assume that the number of train and test data points that land in a leaf are roughly equal: $|I_{\text{Leaf}_j}^{(\text{train})}| \approx |I_{\text{Leaf}_j}|$. Since for all $x \in I_{\text{Leaf}}$, $V_j^{(t)}(x)$ is the same, we simplify ∇B further:

$$\eta \textstyle\sum_{i=1}^{n} f^{(t)}(x_i) = \eta \sum_{j=1}^{|\text{Leaves}(f^{(t)})|} \sum_{x\in I_{\text{Leaf}_j}} V_j^{(t)}(x)$$

if $\lambda = 0$ and since for regression the Hessian $h^{(t)}(f^{(t)}(x_i), y_i) = 1$

$$\begin{aligned}&= -\eta \textstyle\sum_{j=1}^{|\text{Leaves}(f^{(t)})|} \frac{|I_{\text{Leaf}_j}|}{|I_{\text{Leaf}_j}^{(\text{train})}|} \sum_{(x_i,y_i)\in I_{\text{Leaf}}^{(\text{train})}} g(\phi^{(t)}(x_i), y_i) \\ &\approx -\eta \textstyle\sum_{i=1}^{n} g(\phi^{(t)}(x_i), y_i). \end{aligned} \tag{7}$$

Thus, we can conclude as a stopping criterion

$$\nabla B \approx -\eta \textstyle\sum_{i=1}^{n} g(\phi^{(t)}(x_i), y_i) \approx 0, \tag{8}$$

i.e., that if we stop the training when the sum of the training gradients is zero, the bias error difference quotient ∇B is approximately zero; thus, we probably reach a saturation point in the bias which may keep the learnable correlated component of the MSE small. Naturally, if the systematic "bias" error vanishes, only the variance error is left, which marks a good heuristic to stop early.

6.2. Algorithm Overview

Algorithm 6: Training of EARLYSTOPPEDSBDT.

Input: T: maximal number of rounds, D: training data, (r_1, r_2): noise weights for leaf value, σ_{leaf}^2: leaf noise scale, d: depths of trees, g^*: gradient clipping bound, σ_{CI}: cutoff multiplier

$f = (f^{(0)}))$; `// ensemble incl. init score`
$\tau = \sigma_{\text{leaf}} \cdot g^* \cdot \sqrt{1/2r_1} \cdot \sqrt{2^d}$; `// cutoff threshold`
$(\Sigma g, \text{dir}) = (0, \texttt{UNDEF})$;
for $t = 1$ **to** T **do** `// train tree` $f^{(t)}$
  `// Alg 1: train` $f^{(t)}$ `and append to` f
  `// Phase I:` $\tilde{g}_j^{(t)}$ `in Alg 1 in Alg 1`
  $\Sigma g \mathrel{+}= \text{sum}_j(\tilde{g}_j^{(t)})$;
  if $\text{dir} = \textit{POS}$ **then** $\Sigma g = \min(\Sigma g, 0)$;
  else if $\text{dir} = \textit{NEG}$ **then** $\Sigma g = \max(\Sigma g, 0)$;
  `// Phase II`
  ε_t = `RDPAccountant` $(\ldots, \sigma_{\text{leaf}}^2, t, \ldots)$;
  $\tau_{\text{CI}} = 10^{\varepsilon_t} \cdot \sigma_{\text{CI}} \cdot \tau$;
  switch dir **do**
    case *UNDEF* **do**
      if $\Sigma g \le -\tau_{CI}$ **then** $\text{dir} = \texttt{NEG}$;
      if $\Sigma g \ge \tau_{CI}$ **then** $\text{dir} = \texttt{POS}$;
    case *POS* **do**
      if $t \ge 10 \wedge \Sigma g \le -\tau_{CI}$ **then break loop**;
    case *NEG* **do**
      if $t \ge 10 \wedge \Sigma g \ge \tau_{CI}$ **then break loop**;
return f;

Algorithm 6 leverages our theoretical insight from Section 6.1 for an early tree stopping heuristic that halts as soon as the sum of gradients across the leaves is small. In yellow, we state the new parts compared to the vanilla S-BDT training skeleton of Algorithm 1. Our EARLYSTOPPEDSDBT works in two phases: after training a single tree using S-BDT (cf. Algorithm 6), we (Phase I) build the early stopping criterion Σg solely based on post-processing the sum of noisy gradients across the tree's leaves ($\text{sum}_j(g_j^{(t)})$) and (Phase II) stop training early if Σg meets the dynamic threshold τ_{CI}. Since the gradients are noised, we do not halt exactly as in Equation (8) ($\text{sum}_j(g_j^{(t)}) = 0$) but when a clear direction shift is detected.

Phase I: Build Σg (Post-Processing). Algorithm 6 describe Σg as a modified cumulative sum of gradients across the trees: for instance, we set $\text{dir} = \texttt{POS}$; the gradient sum

is positive for the first 20 trees, and it becomes negative starting at tree 21. Then, we take the cumulative sum of all gradients starting from tree 21 until the cumulative sum is larger than or equal to zero again, which repeats this process. This way, we ensure that we only halt if there is a clear change in the sign of the gradient sum, which indicates an extremum in the bias error. To detect a clear change in the sign of the gradient sum, we define dir as the sign (positive (POS) or negative (NEG)) of how the gradient sum progresses during early training in Algorithm 6. Thus, we learn whether we should halt on a positive or negative change in the sign of the gradient sum. We use the same dynamic cutoff threshold τ_{CI} of Phase II to lock in dir. We set the gradient sum of a leaf to zero if the noised leaf denominator is smaller than zero (similarly, in this case, S-BDT sets the prediction of this leaf to zero).

Phase II: Early Stop If Σg Meets the Dynamic Threshold τ_{CI}. We stop training in Algorithm 6 based on the cutoff threshold τ_{CI}, divided into a static (τ, cf. Algorithm 6) and a dynamic part (cf. Algorithm 6).
Static part: τ depends on the expected standard deviation of the noise on the per-leaf gradient sum: $\sigma_{\text{leaf}} \cdot g^* \cdot \sqrt{1/2r_1}$. As we sum the gradients over 2^d leaves, we also sum the noise over them. For $n = 2^d$ normally distributed random variables $X_1, \ldots, X_n$ with said standard deviation, we know that the sum of these random variables, i.e. $\sum_{i=1}^{n} X_i$, equals to a random variable with a standard deviation of $\sqrt{\sum_{i=1}^{n} \sigma_{\text{leaf}}^2 \cdot g^{*2} \cdot 1/2r_1} = \sigma_{\text{leaf}} \cdot g^* \cdot \sqrt{1/2r_1} \cdot \sqrt{2^d} =: \tau$.
Dynamic part: Based on τ, we further scale the cutoff with a multiplier of σ_{CI}, similar to a confidence interval, to ensure with high certainty that the current change in direction of the gradient sum signal was not due to noise. We additionally find that scaling τ with 10^{ε_t} provides a dynamic aspect to the early tree stopping, with the goal of not accepting a constant number of trees among all ε values but more trees for higher ε values. At higher ε values, the training uses less noise, so we trust the self-correction of the learning process (i.e., use a higher cutoff τ_{CI} that is less sensitive to fluctuations) more than for lower ε where the noise is high such that one noise sample may destroy all learning process. To determine ε, we call the RDP accountant (cf. Algorithm 6) that we notate in a black-box manner. The RDP accountant tracks the currently consumed privacy budget and, based on the RDP-to-DP conversion Appendix B.3, outputs the ε_t for the current number of trees t.

6.3. Privacy Implications

Our early stopping is adaptive to the learning task by only using S-BDT's DP approximations of gradient sums (Σg). This constitutes post-processing, which incurs no extra privacy leakage (cf. Theorem 4). A mechanism also remains RDP if it adaptively uses the output of a previous one (so-called adaptive sequential composition) [42, Proposition 1].

Early Stopping and Privacy Filters. If we stop S-BDT training early, we do not leak privacy for trees that we did not train. However, simply reducing the privacy budget $\rho(\alpha)$ by the number of skipped trees does not necessarily imply DP with this $\rho(\alpha)$ since DP is an a priori guarantee before the mechanism is executed. Yet, it is inherent to early stopping that we do not know beforehand when we will stop. Thus, in early stopping, we can only guarantee this property before training the next tree, since only then do we know that we did not stop after the current tree. In an extreme case, an attacker could choose a neighboring dataset pair such that early stopping never works, and we always train for T rounds, which still preserves DP but with the original privacy budget.

So-called *Privacy filters* [18]–[20] offer a solution to this a-posteriori leakage saving. S-BDT already uses an RDP privacy filter [19] for continuous learning. In this privacy filter, we can run arbitrarily many adaptive RDP mechanisms, S-BDT among them, and only halt if a previously defined privacy budget $\rho(\alpha)$ is exceeded. For that, we use the $\rho(\alpha)$ associated with the maximal number of trees as this budget, but can use the $\rho(\alpha)$ saved by stopping early for other RDP mechanisms on the same dataset. For compatibility, we only report the $\rho(\alpha)$ spent on S-BDT in our experiments.

7. Evaluation

We test MammothDP's full system with its key components—constant-time implementation of S-BDT, improved rollback protection, and early tree stopping—on two TEEs: a *TDX*-enabled *Intel Xeon Gold 6526Y Emerald Rapids* and an *SEV*-enabled *AMD EPYC 7763* processor. We provide an Ubuntu 24.10 image with a compiled MammothDP binary[3] and MammothDP's code[4].

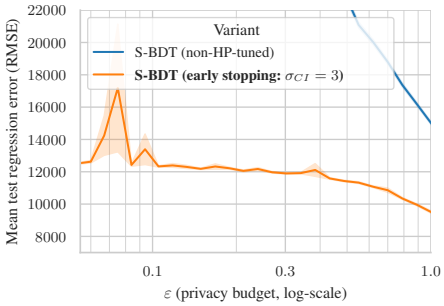
Structure. We extensively evaluate *MammothDP* with regard to constant-time verification (cf. Section 7.1), early stopping (cf. Section 7.2), and runtime overhead (cf. Section 7.3).

7.1. Constant-Time Verification

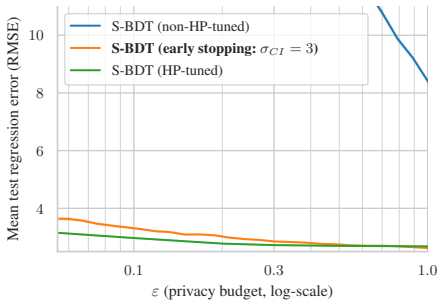
Constant-time code does not necessarily guarantee security against timing attackers. For example, subtle leakages may be missed [64], [65], or compiler optimizations may reintroduce vulnerabilities [66], [67]. Thus, we must verify compiled binaries. We use Microwalk [33], [68], a dynamic timing side-channel analysis framework. For Microwalk's analysis, see Appendix B.1.

For the analysis, we divided data-dependent parts of our implementation into independent components. For each component, we generated 100 random test inputs. These are loaded by thin wrapper functions, which transform the test inputs into the correct format (while maintaining uniformity)

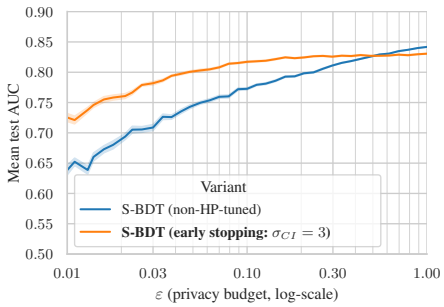
3. https://github.com/kirschte/MammothDP/tree/main/tee-ready-image
4. https://github.com/kirschte/MammothDP



(a) Test (*Insurance*), ↓ is better

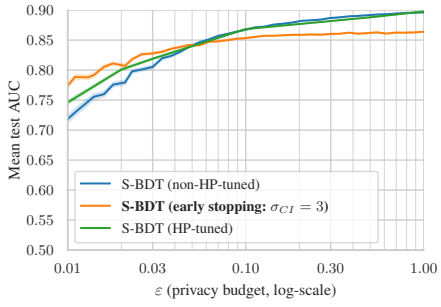


(a) Comparison (*Abalone*), ↓ is better

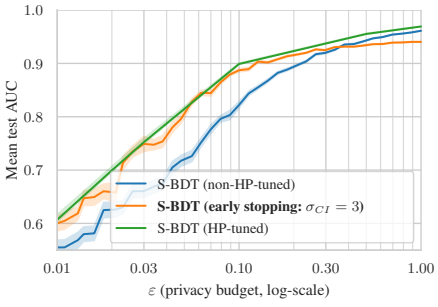


(b) Test (*Credit*), ↑ is better

Figure 4: **Main Result**: Privacy-utility tradeoff on test data comparing our early stopping (orange) against the baseline of purely statically chosen hyperparameters (blue). Top: Regression; Bottom: Classification.



(b) Comparison (*Adult*), ↑ is better



(c) Comparison (*Spambase*), ↑ is better

Figure 5: **Comparison to HP-tuned S-BDT**: Privacy-utility tradeoff on comparison data comparing our early stopping (orange) against the baselines of purely statically chosen hyperparameters (blue) and tuned yet privacy-leaky hyperparameters (green). Top: Regression; Bottom: Classification.

and then call the target component. We embed the wrapper functions into Microwalk's new analysis template [69], which automates communication with Microwalk and loading and executing the test inputs. The resulting analysis workflow is fully automatic, which makes re-verifying the full implementation after changes straightforward.

Microwalk verifies all components, without reporting leakages. The analysis covered all executed S-BDT code, and increasing the number of test cases does not raise coverage. We conclude that our implementation exhibits no data-dependent control flow or memory accesses, making it robust against system-level attackers.

7.2. Early Stopping (Privacy-Utility Tradeoff)

We test the privacy-utility tradeoff on five datasets (cf. Table 1) that we describe in Appendix C.1 in more detail.

TABLE 1: Sensitive Datasets.

Name	Type	Size	#Attributes
Insurance [70]	Regression	1,300	6
Abalone [26]	Regression	4,200	8
Credit [71]	Classification	120,300	10
Adult [72]	Classification	48,800	14
Spambase [73]	Classification	4,600	57

7.2.1. How does the privacy-utility tradeoff of early stopped S-BDT compare?. In Figures 4 and 5, we compare S-BDT with leakage-free hyperparameters in the vanilla and early stopping (cf. Algorithm 6 on $\sigma_{\text{CI}} = 3$) variant, and, as a reference, we include S-BDT with privacy-leaky hyperparameters [21, Figure 3]. For compatibility, we only report the $\rho(\alpha)$—converted to (ε, δ)-DP—spent on S-BDT (cf. Section 6.3 for the Rényi Filter discussion). We also bucket similar actually consumed privacy budgets that vary due to early stopping into bins for better plot readability.

Experimental Setup. We set $\delta = 5 \cdot 10^{-8}$. We evaluate early stopping with 20 runs of 5-fold cross-validation, except for the *Insurance* (100 runs) and *Abalone* (50 runs) datasets. For both S-BDT variants with leakage-free hyperparameters, we chose a static set of hyperparameters based on the compromise of the best-performing hyperparameters in HP-tuned S-BDT on *Abalone*, *Adult*, and *Spambase*. Appendix C.2 lists them.

Comparison vs. Test Datasets. Our three comparison datasets (*Abalone*, *Adult*, and *Spambase*) are the same as in S-BDT [21] and serve to determine the static hyperparameters. For comparability, we reuse S-BDT's attribute and regression value ranges, which are listed in Appendix C.2. To illustrate the performance gain in the leakage-free hyperparameter setting of early-stopped and vanilla S-BDT, we chose the two test datasets (*Insurance* and *Credit*) that were not used to determine the static set of reasonable hy-

perparameters, and attribute pre-processing has been limited to taking a numerical attribute range and a regression value range on abstract metadata.

Results. In the leakage-free hyperparameter setting, early-stopped S-BDT significantly outperforms non-HP-tuned S-BDT on both regression datasets, regardless of whether test or comparison datasets are used. For classification, early stopping only outperforms S-BDT in the lower ε regime. For all comparison datasets, we reach a lower but comparable utility when comparing early-stopped S-BDT to the reference S-BDT with privacy-leaky hyperparameters.

Ablation on (maximal) Number of Trees T. We show in Figures 11 and 12 how other initial guesses of the current (maximal) number of trees $T = 6{,}000$ impact the privacy-utility tradeoff.

7.2.2. Is early stopping actually adaptive?. In Figures 8 and 9, we visualize the actual number of chosen trees for all three variants. These show for the regression datasets, that early stopping does indeed select the number of trees adaptively and that, as designed, early-stopped S-BDT selects more trees, the larger ε grows. A similar, although less distinct, pattern is also present in HP-tuned S-BDT. For classification, the adaptive nature of early stopped S-BDT is visible for *Spambase* but not for *Credit* and *Adult*.

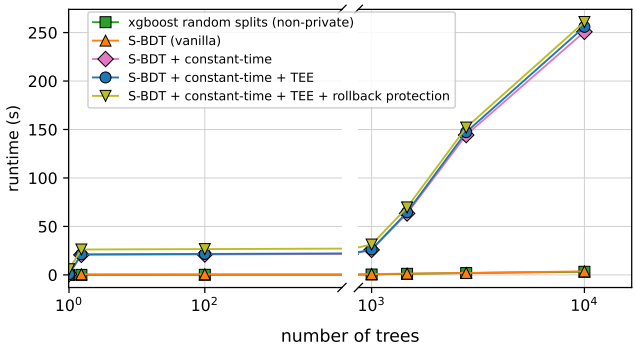
7.2.3. Is it justified to assume that A-I) 15 hyperparameters can be fixed statically across ε values and datasets and A-II) the number of trees cannot?. We illustrates both in Figure 12 on comparison data (where static hyperparameters can be correlated with the aggregate of all optimal ones, cf. Section 7.2): (A-I) the gap between HP-tuned (green, tuned per ε and dataset) and non-HP-tuned (blue, static hyperparameters) is small, (A-II) but only for the right number of trees which varies strongly per $(\varepsilon, \text{dataset})$: (high ε, adult) 6000 trees, (low ε, adult) 600 trees, (high ε, abalone) 60 trees.

7.3. Runtime overhead

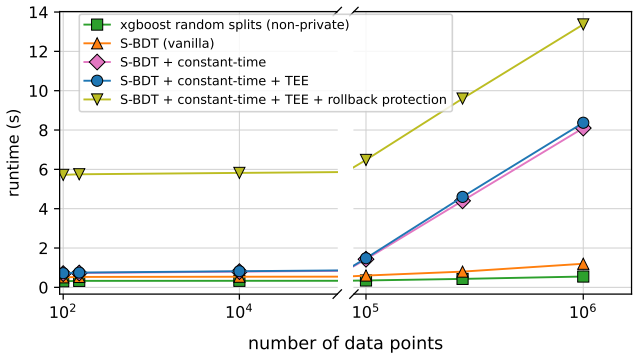
7.3.1. What is *MammothDP*'s runtime overhead?. In Figure 6, we compare MammothDP's runtime overhead to vanilla S-BDT and non-private XGBoost [39], and pin down the overhead of the constant-time implementation, the TEE, and the rollback protection.

Our measurements highlight one key effect: the most runtime overhead is due to the constant-time implementation, which scales linearly in both dataset size and number of trees. The overhead of the constant-time implementation is due to fixed-time instructions taking more clock cycles to run [32, Figure 14], and linear scans over bitmasks of the entire dataset instead of just the current subsample.

For rollback protection alone, we measure 0.5 seconds for initialization, 5.0 seconds for one training call, and 5.0 seconds for recovery of benign execution crashes. Most runtime is used for authentication and nonce verification. Sealing and unsealing only take 0.001 seconds each. Using a TEE incurs $0.02 - 5$ seconds overhead.



(a) Training runtime on *Abalone* vs. number of trees.



(b) Training runtime of one tree vs. number of data points.

Figure 6: **Runtime** in seconds of MammothDP's components. MammothDP consists of a constant-time implementation of S-BDT with early tree stopping, a TEE port, and rollback protection.

7.3.2. How does *MammothDP*'s runtime overhead compare to other solutions?. Our constant-time S-BDT implementation incurs factor $1.6 - 69.4$ overhead over vanilla S-BDT. Oblivious Secure XGBoost [9], a constant-time, secure and collaborative version of XGBoost [39], incurs a factor of $16.7 - 178.2$ overhead over vanilla Secure XGBoost. The specific overhead depends on a hyperparameter that must be tuned. Furthermore, our work, unlike Oblivious Secure XGBoost, also defends against attacks based on instruction runtime, which gives us an additional overhead.

TEE and rollback protection of MammothDP incur a factor of $2.8 - 8.3$ overhead over vanilla S-BDT. ElephantDP [17], a state-of-the-art rollback protection for DP algorithms, incurs a factor of $1.1 - 3.9$ overhead over vanilla DP approximated average, variance, and Pearson correlation coefficient, and private multiplicative weights.

Our TEE setup with rollback protection takes $5.3 - 5.7$ seconds for training one tree with vanilla S-BDT. MPC-based GBDT solutions [74], [75] take $29 - 865$ seconds to train one tree.

8. Conclusion

We introduced *MammothDP*, a significant milestone towards a deployable DP system for data spaces that protects

the processing of data and the release of studies alike. By combining DP, TEEs, and constant-time programming, MammothDP addresses privacy and security requirements relevant to the European Health Data Space. MammothDP is not a one-size-fits-all TEE-based DP tree ensemble learner but shows a design that can reasonably trade off partially contradicting goals of a data space: low computational overhead, low communication overhead, strong privacy guarantees, limited utility loss, no TEE rollbacks, no required Rényi filter, and timing side-channel protection. In detail, MammothDP utilizes two novel components: an improved rollback protection and a post-processing-based early stopping rule that allows adaptive hyperparameter tuning without extra privacy budget and thus attains an improved privacy-utility tradeoff for released studies.

References

[1] M. Franklin, A. Halevy, and D. Maier, "From databases to dataspaces: a new abstraction for information management," *SIGMOD Rec.*, vol. 34, no. 4, p. 27–33, 2005.

[2] (2026) Common european data spaces. European Commission. [Online]. Available: https://digital-strategy.ec.europa.eu/en/policies/data-spaces

[3] C. o. t. E. U. European Parliament, "REGULATION (EU) 2025/327 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 11 February 2025 on the European Health Data Space and amending Directive 2011/24/EU and Regulation (EU) 2024/2847," *OJ*, vol. L 327, 2025.

[4] A. Halevy, M. Franklin, and D. Maier, "Principles of dataspace systems," in *PODS*. New York, NY, USA: ACM, 2006, p. 1–9.

[5] Intel, "Intel tdx," White Paper, 2023, [Accessed: 2025-01-02]. [Online]. Available: https://cdrdv2.intel.com/v1/dl/getContent/690419

[6] Kaplan, David and Powell Jeremy and Woller, Tom, "Amd memory encryption," White Paper, 2016, [Accessed: 2025-01-02]. [Online]. Available: https://www.amd.com/content/dam/amd/en/documents/epyc-business-docs/white-papers/memory-encryption-white-paper.pdf

[7] M. Hamburg, "Accelerating aes with vector permute instructions," in *CHES*. Springer Berlin Heidelberg, 2009, pp. 18–32.

[8] E. Brickell, G. Graunke, and J.-P. Seifert, "Mitigating cache-timing based side-channels in aes and rsa software implementations," in *Conference 2006 session DEV-203*. RSA, 2006.

[9] A. Law, C. Leung, R. Poddar, R. A. Popa, C. Shi, O. Sima, C. Yu, X. Zhang, and W. Zheng, "Secure collaborative training and inference for xgboost," in *PPMLP*. New York, NY, USA: ACM, 2020, p. 21–26.

[10] O. Ohrimenko, F. Schuster, C. Fournet, A. Mehta, S. Nowozin, K. Vaswani, and M. Costa, "Oblivious Multi-Party machine learning on trusted processors," in *USENIX Security*. Austin, TX: USENIX Association, 2016, pp. 619–636.

[11] C. Dwork, F. McSherry, K. Nissim, and A. D. Smith, "Calibrating noise to sensitivity in private data analysis," in *TCC*, ser. Lecture Notes in Computer Science. Berlin, Heidelberg: Springer Berlin Heidelberg, 2006, pp. 265–284.

[12] B. Parno, J. Lorch, J. J. Douceur, J. Mickens, and J. M. McCune, "Memoir: Practical state continuity for protected modules," in *IEEE S&P*. IEEE, 2011.

[13] S. Matetic, M. Ahmed, K. Kostiainen, A. Dhar, D. Sommer, A. Gervais, A. Juels, and S. Capkun, "{ROTE}: Rollback protection for trusted execution," in *USENIX Security*. Vancouver, BC: USENIX Association, 2017, pp. 1289–1306.

[14] S. Angel, A. Basu, W. Cui, T. Jaeger, S. Lau, S. Setty, and S. Singanamalla, "Nimble: rollback protection for confidential cloud services," in *USENIX OSDI*. Boston, MA: USENIX Association, 2023, pp. 193–208.

[15] J. Niu, W. Peng, X. Zhang, and Y. Zhang, "Narrator: Secure and practical state continuity for trusted execution in the cloud," in *ACM CCS*. New York, NY, USA: ACM, 2022, pp. 2385–2399.

[16] R. Strackx and F. Piessens, "Ariadne: A minimal approach to state continuity," in *USENIX Security*. Austin, TX: USENIX Association, 2016, pp. 875–892.

[17] J. Jin, C. Chuengsatiansup, T. Murray, B. I. P. Rubinstein, Y. Yarom, and O. Ohrimenko, "Elephants do not forget: Differential privacy with state continuity for privacy budget," in *ACM CCS*. ACM, 2024, p. 1909–1923.

[18] R. Rogers, A. Roth, J. Ullman, and S. Vadhan, "Privacy odometers and filters: pay-as-you-go composition," in *NIPS*. Curran Associates Inc., 2016, p. 1929–1937.

[19] V. Feldman and T. Zrnic, "Individual privacy accounting via a rényi filter," in *NeurIPS*, vol. 34. Curran Associates, Inc., 2021, pp. 28 080–28 091.

[20] M. Lécuyer, "Practical privacy filters and odometers with r\'enyi differential privacy and applications to differentially private deep learning," *arXiv preprint arXiv:2103.01379*, 2021.

[21] T. Peinemann, M. Kirschte, J. Stock, C. Cotrini, and E. Mohammadi, "S-bdt: Distributed differentially private boosted decision trees," in *ACM CCS*. New York, NY, USA: ACM, 2024, p. 288–302.

[22] J. V. Bulck, F. Piessens, and R. Strackx, "Nemesis: Studying microarchitectural timing leaks in rudimentary CPU interrupt logic," in *CCS*. New York, NY, USA: ACM, 2018, p. 178–195.

[23] L. Wilke, F. Sieck, and T. Eisenbarth, "Tdxdown: Single-stepping and instruction counting attacks against intel TDX," in *ACM CCS*. ACM, 2024, pp. 79–93.

[24] Z. Ratliff, N. Berrios, and J. Mickens, "Timing attacks on differential privacy are practical," in *CCS*. New York, NY, USA: ACM, 2025, p. 3694–3707.

[25] J. Jin, E. McMurtry, B. I. Rubinstein, and O. Ohrimenko, "Are we there yet? timing and floating-point attacks on differential privacy systems," in *IEEE S&P*. IEEE, 2022, pp. 473–488.

[26] W. Nash, T. Sellers, S. Talbot, A. Cawthorn, and W. Ford, "Abalone," UCI Machine Learning Repository, 1995. [Online]. Available: https://archive.ics.uci.edu/dataset/1/abalone

[27] N. Carlini, S. Chien, M. Nasr, S. Song, A. Terzis, and F. Tramèr, "Membership inference attacks from first principles," in *S&P*, 2022.

[28] R. K. Zhao, R. Steinfeld, and A. Sakzad, "Facct: Fast, compact, and constant-time discrete gaussian sampler over integers," *IEEE Transactions on Computers*, vol. 69, no. 1, pp. 126–137, 2020.

[29] Z. Ratliff and S. Vadhan, "A framework for differential privacy against timing attacks," in *ACM CCS*. ACM, 2024, p. 3615–3629.

[30] N. Papernot and T. Steinke, "Hyperparameter tuning with renyi differential privacy," in *ICLR*, 2022.

[31] J. Liu and K. Talwar, "Private selection from private candidates," in *ACM STOC*. ACM, 2019, pp. 298–309.

[32] M. Andrysco, D. Kohlbrenner, K. Mowery, R. Jhala, S. Lerner, and H. Shacham, "On subnormal floating point and abnormal timing," in *IEEE S&P*, 2015, pp. 623–639.

[33] J. Wichelmann, A. Moghimi, T. Eisenbarth, and B. Sunar, "Microwalk: A framework for finding side channels in binaries," in *ACSAC*. ACM, 2018, p. 161–173.

[34] M. Abadi, A. Chu, I. Goodfellow, H. B. McMahan, I. Mironov, K. Talwar, and L. Zhang, "Deep learning with differential privacy," in *CCS*. New York, NY, USA: ACM, 2016, p. 308–318.

[35] R. Iyengar, J. P. Near, D. Song, O. Thakkar, A. Thakurta, and L. Wang, "Towards practical differentially private convex optimization," in *IEEE S&P*, 2019, pp. 299–316.

[36] K. Chaudhuri, C. Monteleoni, and A. D. Sarwate, "Differentially private empirical risk minimization," *J. Mach. Learn. Res.*, vol. 12, p. 1069–1109, 2011.

[37] A. Koskela and T. Kulkarni, "Practical differentially private hyperparameter tuning with subsampling," in *NeurIPS*, vol. 36. Curran Associates, Inc., 2023, pp. 28 201–28 225.

[38] K. Chaudhuri and S. A. Vinterbo, "A stability-based validation procedure for differentially private machine learning," in *NIPS*, vol. 26. Curran Associates, Inc., 2013.

[39] T. Chen and C. Guestrin, "Xgboost: A scalable tree boosting system," in *ACM SIGKDD KDD*. ACM, 2016, p. 785–794.

[40] S. Sasy and O. Ohrimenko, "Oblivious sampling algorithms for private data analysis," *Advances in Neural Information Processing Systems*, vol. 32, 2019.

[41] A. Rényi, "On measures of entropy and information," in *Berkeley symposium on mathematical statistics and probability*, vol. 4. University of California Press, 1961.

[42] I. Mironov, "Rényi differential privacy," in *IEEE CSF*, 2017, pp. 263–275.

[43] Y. Zhu and Y.-X. Wang, "Poisson subsampled rényi differential privacy," in *ICML*, vol. 97. PMLR, 2019, pp. 7634–7642.

[44] J. H. Friedman, "Greedy function approximation: a gradient boosting machine," *Annals of statistics*, pp. 1189–1232, 2001.

[45] M. Bojarski, A. Choromanska, K. Choromanski, and Y. LeCun, "Differentially- and non-differentially-private random decision trees," *preprint arXiv:1410.6973*, 2014.

[46] V. Costan and S. Devadas, "Intel sgx explained," Cryptology ePrint Archive, Paper 2016/086, 2016.

[47] S. Pinto and N. Santos, "Demystifying arm trustzone: A comprehensive survey," *ACM computing surveys (CSUR)*, 2019.

[48] P.-C. Cheng, W. Ozga, E. Valdez, S. Ahmed, Z. Gu, H. Jamjoom, H. Franke, and J. Bottomley, "Intel tdx demystified: A top-down approach," *ACM Computing Surveys*, vol. 56, no. 9, pp. 1–33, 2024.

[49] X. Li, X. Li, C. Dall, R. Gu, J. Nieh, Y. Sait, and G. Stockwell, "Design and verification of the arm confidential compute architecture," in *USENIX OSDI*, 2022, pp. 465–484.

[50] R. A. Popa, "Confidential computing or cryptographic computing?" *Communications of the ACM*, vol. 67, no. 12, pp. 44–51, 2024.

[51] F. Brasser, U. Müller, A. Dmitrienko, K. Kostiainen, S. Capkun, and A.-R. Sadeghi, "Software grand exposure: Sgx cache attacks are practical," in *USENIX WOOT*. Vancouver, BC: USENIX Association, 2017, p. 11.

[52] F. Dall, G. D. Micheli, T. Eisenbarth, D. Genkin, N. Heninger, A. Moghimi, and Y. Yarom, "Cachequote: Efficiently recovering long-term secrets of sgx epid via cache attacks," *TCHES*, vol. 2018, no. 2, p. 171–191, 2018.

[53] J. Götzfried, M. Eckert, S. Schinzel, and T. Müller, "Cache attacks on intel sgx," in *EuroSec*. New York, NY, USA: ACM, 2017.

[54] M. Hähnel, W. Cui, and M. Peinado, "High-Resolution side channels for untrusted operating systems," in *USENIX ATC*. USENIX Association, 2017, pp. 299–312.

[55] A. Moghimi, G. Irazoqui, and T. Eisenbarth, "Cachezoom: How sgx amplifies the power of cache attacks," in *CHES*. Springer International Publishing, 2017, pp. 69–90.

[56] M. Schwarz, S. Weiser, D. Gruss, C. Maurice, and S. Mangard, "Malware guard extension: Using sgx to conceal cache attacks," in *DIMVA*, 2017.

[57] S. Lee, M.-W. Shih, P. Gera, T. Kim, H. Kim, and M. Peinado, "Inferring fine-grained control flow inside SGX enclaves with branch shadowing," in *USENIX Security*. Vancouver, BC: USENIX Association, 2017, pp. 557–574.

[58] O. Aciiçmez, Ç. K. Koç, and J.-P. Seifert, "On the power of simple branch prediction analysis," in *ASIACCS*. New York, NY, USA: ACM, 2007, p. 312–320.

[59] J. V. Bulck, N. Weichbrodt, R. Kapitza, F. Piessens, and R. Strackx, "Telling your secrets without page faults: Stealthy page Table-Based attacks on enclaved execution," in *USENIX Security*. USENIX Association, 2017, pp. 1041–1056.

[60] Y. Xu, W. Cui, and M. Peinado, "Controlled-channel attacks: Deterministic side channels for untrusted operating systems," in *S&P*, 2015.

[61] D. A. Osvik, A. Shamir, and E. Tromer, "Cache attacks and countermeasures: The case of aes," in *Topics in Cryptology – CT-RSA 2006*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2006, pp. 1–20.

[62] A. Karmakar, S. S. Roy, O. Reparaz, F. Vercauteren, and I. Verbauwhede, "Constant-time discrete gaussian sampling," *IEEE Transactions on Computers*, vol. 67, no. 11, pp. 1561–1571, 2018.

[63] L. Groot Bruinderink, A. Hülsing, T. Lange, and Y. Yarom, "Flush, gauss, and reload–a cache attack on the bliss lattice-based signature scheme," in *CHES*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2016, pp. 323–345.

[64] F. Sieck, S. Berndt, J. Wichelmann, and T. Eisenbarth, "Util::lookup: Exploiting key decoding in cryptographic libraries," in *ACM CCS*. ACM, 2021, pp. 2456–2473.

[65] S. Weiser, D. Schrammel, L. Bodner, and R. Spreitzer, "Big numbers - big troubles: Systematically analyzing nonce leakage in (EC)DSA implementations," in *USENIX Security*, 2020.

[66] L. Daniel, S. Bardin, and T. Rezk, "Binsec/rel: Symbolic binary analyzer for security with applications to constant-time and secret-erasure," *ACM Trans. Priv. Secur.*, vol. 26, no. 2, pp. 11:1–11:42, 2023.

[67] L. Simon, D. Chisnall, and R. J. Anderson, "What you get is what you C: controlling side effects in mainstream C compilers," in *IEEE S&P*. IEEE, 2018, pp. 1–15.

[68] J. Wichelmann, F. Sieck, A. Pätschke, and T. Eisenbarth, "Microwalk-ci: Practical side-channel analysis for javascript applications," in *ACM CCS*. ACM, 2022.

[69] I. Fayolle, J. Wichelmann, A. Köhl, W. Rudametkin, T. Eisenbarth, and C. Maurice, "Semi-automated and easily interpretable side-channel analysis for modern javascript," in *CANS*. Berlin, Heidelberg: Springer-Verlag, 2024, p. 25–46.

[70] mosap abdelghany, "Medical insurance cost dataset," 2025. [Online]. Available: https://www.kaggle.com/dsv/12853160

[71] C. Fusion and W. Cukierski, "Give me some credit," https://kaggle.com/competitions/GiveMeSomeCredit, accessed via https://github.com/DrIanGregory/Kaggle-GiveMeSomeCredit by Ian Gregory, 2011.

[72] B. Becker and R. Kohavi, "Adult," UCI Machine Learning Repository, 1996. [Online]. Available: https://archive.ics.uci.edu/dataset/2/adult

[73] M. Hopkins, E. Reeber, G. Forman, and J. Suermondt, "Spambase," UCI Machine Learning Repository, 1999. [Online]. Available: https://archive.ics.uci.edu/dataset/94/spambase

[74] A. Song, S. Cui, J. Bai, K. Cheng, Y. Shen, and G. Russello, "Guard-gbdt: Efficient privacy-preserving approximated gbdt training on vertical dataset," arXiv:2507.20688 [cs.CR], arXiv, 2025.

[75] Y. Jiang, F. Mei, T. Dai, and Y. Li, "Sigbdt: Large-scale gradient boosting decision tree training via function secret sharing," in *ASIA CCS*. New York, NY, USA: ACM, 2024, p. 274–288.

[76] S. Maddock, G. Cormode, T. Wang, C. Maple, and S. Jha, "Federated boosted decision trees with differential privacy," in *CCS*. New York, NY, USA: ACM, 2022, p. 2249–2263.

[77] M. Backes, P. Druschel, A. Haeberlen, and D. Unruh, "CSAR: A practical and provable technique to make randomized systems accountable," in *NDSS*. The Internet Society, 2009.

[78] M. Backes, D. Fiore, and E. Mohammadi, "Privacy-preserving accountable computation," in *Computer Security – ESORICS 2013*, ser. Lecture Notes in Computer Science, vol. 8134. Berlin, Heidelberg: Springer Berlin Heidelberg, 2013, pp. 38–56.

[79] A. Geimer, M. Vergnolle, F. Recoules, L. Daniel, S. Bardin, and C. Maurice, "A systematic evaluation of automated tools for side-channel vulnerabilities detection in cryptographic libraries," in *ACM CCS*. ACM, 2023, pp. 1690–1704.

[80] L. Ducas, A. Durmus, T. Lepoint, and V. Lyubashevsky, "Lattice signatures and bimodal gaussians," Cryptology ePrint Archive, Paper 2013/383, 2013.

[81] J. W. Bos, C. Costello, M. Naehrig, and D. Stebila, "Post-quantum key exchange for the tls protocol from the ring learning with errors problem," in *IEEE S&P*, 2015, pp. 553–570.

[82] D. M. Sommer, S. Meiser, and E. Mohammadi, "Privacy loss classes: The central limit theorem in differential privacy," *PoPETs*, 2019.

[83] B. Balle, G. Barthe, M. Gaboardi, J. Hsu, and T. Sato, "Hypothesis testing interpretations and renyi differential privacy," in *AISTATS*, ser. PMLR, vol. 108. PMLR, 2020, pp. 2496–2506.

[84] C. L. Canonne, G. Kamath, and T. Steinke, "The discrete gaussian for differential privacy," in *NeurIPS*, vol. 33. Curran Associates, Inc., 2020, pp. 15 676–15 688.

[85] (2025) The sodium cryptography library (libsodium). Libsodium Project. [Online]. Available: https://libsodium.gitbook.io/doc

Appendix Overview

Appendix A: Non-TEE-based Related Work 16

Appendix B: Detailed Background 16
B.1 Microwalk 16
B.2 FACCT Discrete Gaussian Sampling . 17
B.3 RDP-to-DP conversion 17

Appendix C: Extended Evaluation 17
C.1 Dataset Description (cf. Table 1) . . . 17
C.2 Static Hyperparameters 18
C.3 Adaptive Number of Trees 18
C.4 Ablation on (Maximal) Number of Trees T 18

Appendix D: Rollback Protection Details 18
D.1 System and Adversary Model 18
D.2 Rollback Protection Algorithms . . . 20
D.2.1 Implementation 21
D.3 Security Analysis 21

Appendix E: Timing Privacy 22

Appendix F: Pseudocode for Constant-Time S-BDT 23

Appendix A. Non-TEE-based Related Work

Secure DP-ML processing without a TEE but an MPC protocol. Secure multiparty computation protocols (MPC, a.k.a. secure computation) would technically provide an alternative avenue towards confidential, trustworthy, and accountable execution of a DP mechanism. Admittedly, MPC-based approaches would be free from vendor-specific vulnerabilities and having to trust the vendors. Yet, some of the computation parties would instead need to be trusted. To prevent malicious noise generation, the MPC implementation would need to include secure noise generation. The rollback protection would be ensured by trusting some of the computation parties and by requiring that the MPC protocol is secure against active attackers. As our early stopping mechanism requires a private threshold check, relying on secure aggregation alone (as in [21], [76]) would not be sufficient. Hence, the entire computation of all trees (cf. Figures 8 and 9 for the number of trees) would have to be done in MPC. As a result, the computational costs would be orders of magnitude higher (even when including the overhead due to the constant-time implementation and rollback protection) and it would incur a very large communication cost overhead, with existing MPC protocols from the literature [74], [75].

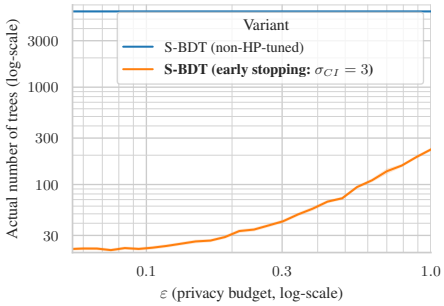
Secure DP-ML processing without a TEE but an accountable computation protocol. Another line of related work is that of accountable computation [77], [78]. Those results solely rely on cryptographic assumptions and a secure logging mechanism. Yet, to the best of our knowledge, existing work does not enable accountable computation of DP algorithms. Moreover, these accountable computation approaches do not tackle the topic of rollback protection, which is essential for satisfying differential privacy.

Appendix B. Detailed Background

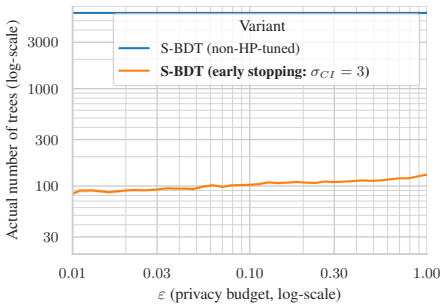
B.1. Microwalk

There has been much research in automated constant-time verification, and many tools have been proposed [79]. One of these tools is Microwalk [33], [68], a dynamic timing side-channel analysis framework which has, since its initial proposal, matured to a stable and practically usable tool.

Microwalk uses a dynamic approach, i.e., it analyzes a program for a concrete set of random inputs, which are carefully crafted to achieve high implementation coverage. For every such input, Microwalk collects an execution trace with all taken branches and accessed memory addresses, which resembles an overapproximation of the information a powerful timing side-channel attacker can acquire. The subsequent timing side-channel leakage analysis follows a simple idea: If all these traces are *identical*, the random inputs led to the same execution path, i.e., they are indistinguishable for a timing side-channel attacker. On the other hand, if there are *differences* between these traces, the attacker can distinguish the inputs and thus learn (partial) information. Microwalk compares execution traces and computes a leakage score, indicating how much information a

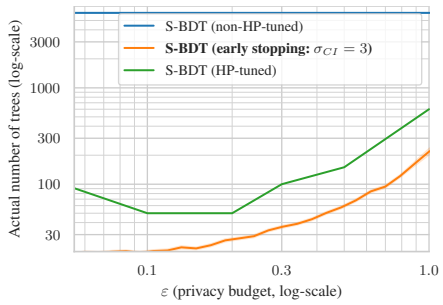


(a) Test (*Insurance*)

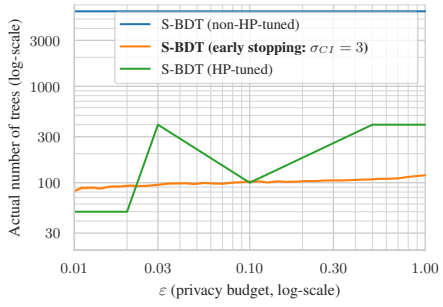


(b) Test (*Credit*)

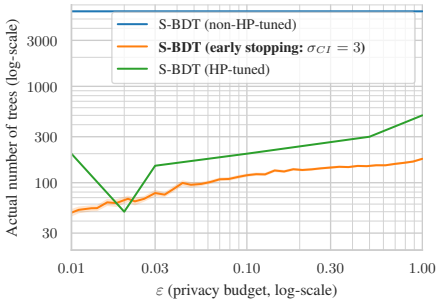
Figure 8: **Actual number of trees** on test data for our early-stopped S-BDT (orange) and, as a reference, the S-BDT baseline of purely statically chosen hyperparameters (blue). Top: Regression; Bottom: Classification.



(a) Comparison (*Abalone*)



(b) Comparison (*Adult*)



(c) Comparison (*Spambase*)

Figure 9: **Actual number of trees** on comparison data for our early-stopped S-BDT (orange) and, as a reference, the S-BDT baselines of purely statically chosen hyperparameters (blue) and tuned yet privacy-leaky hyperparameters (green). Top: Regression; Bottom: Classification. Note that the zigzags in HP-tuned S-BDT might be an artifact of the HP-search where 1) the number of trees is discretized and 2) a different number of trees might only be infinitesimally worse than the reported one.

timing side-channel attacker would get in the worst case. To aid fixing the identified vulnerabilities, Microwalk outputs information about the source code location and witness inputs that trigger the vulnerability.

B.2. FACCT Discrete Gaussian Sampling

For a discrete Gaussian D_σ with $\sigma = k \cdot \sigma_0$ and $\sigma_0 = \sqrt{1/(2\ln 2)}$, FACCT uses the binary sampling method of the BLISS signature scheme [80]: first call the base sampler to generate a sample $x \sim \mathcal{D}^+_{\sigma_0}$ from a positive discrete Gaussian with standard deviation σ_0. The base sampler uses an adaptation of the inversion method from Bos et al. [81]. The inversion method samples $x \sim \text{pdf}_f$ from a probability density function pdf_f by sampling $u \sim \mathcal{U}([0,1])$ and then computing $F_f^{-1}(x)$ with the inverse CDF F_f^{-1}. This approach can be implemented in constant-time using a full-table access CDT sampler.

Now, generate $y \sim \mathcal{U}(\{0,1,...,k-1\})$, set $z \coloneqq kx+y$, $t \coloneqq y(y+2kx)$ and perform rejection sampling on z with rejection rate $p = \exp(-y(y+2kx)/(2\sigma^2))$ using a Bernoulli sampler. The Bernoulli sampler needs to compute p first to generate a sample. Zhao et al. [28] propose to compute a polynom P as an approximation of 2^x for $0 \le x < 1$ which is then further used to compute p (cf. [28, Figure 8]). Zhao et al. find a polynom P that has maximal relative error $\max()_x \left|\frac{P(x)-2^x}{2^x}\right| < 2^{-45}$. They evalute P which has degree n and coefficients $(a_i)_{i=1}^n$ by using Horner's rule $(H(x))$ with δ_{FP}-bit precision, yielding absolute error $|P(x)-H(x)| \le \gamma_{2n} \cdot \sum_{i=0}^n |a_i| \cdot |x|^i$, where $\gamma_{2n} \approx 2n \cdot 2^{-\delta_{\text{FP}}}$. Evaluating the polynom is possible in constant-time because the degree and precision is fixed.

The probability of outputting an integer $z = kx+y$ is now proportional to $\exp(-z^2/(2\sigma^2))$ ([28, Theorem 3]).

B.3. RDP-to-DP conversion

With Theorem 5, we can convert RDP to DP. For a tight conversion, we refer to [82, Theorem 2] which requires access to all α.

Corollary 5 (RDP to DP [83, Thm. 21], [84, Prop. 12])**.** *For any $\delta \in [0,1]$, if a mechanism is $(\alpha, \rho(\alpha))$-RDP, then it is (ε, δ)-DP with $\varepsilon = \rho(\alpha) + \log(\frac{\alpha-1}{\alpha}) - \frac{\log(\delta)+\log(\alpha)}{\alpha-1}$.*

Appendix C. Extended Evaluation

C.1. Dataset Description (cf. Table 1)

- *Insurance* predicts the medical insurance premium of the beneficiary based on attributes like age, sex, and children.

- *Abalone* predicts the age of an Abalone based on attributes like sex, length, and diameter.
- *Credit* predicts whether a borrower had a delinquent payment based on attributes like a borrower's monthly income. Here, we removed N/A entries and unlabelled data points.
- *Adult* predicts whether a person earns over 50,000 $ per year based on attributes like age, sex, and occupation.
- *Spambase* predicts whether mail is spam based on attributes like the frequencies of words and symbols in a mail.

C.2. Static Hyperparameters

For both S-BDT variants with leakage-free hyperparameters, we chose the following static set of hyperparameters based on the compromise of the best-performing hyperparameters in HP-tuned S-BDT on the *Abalone*, *Adult*, and *Spambase* datasets:

- learning rate $\eta = 0.1$,
- maximal number of trees $T = 6{,}000$,
- depth of trees $d = 2$,
- adaptive leaf noise ratio $r_1 = 0.4$,
- gradient clipping bound $g^* = 0.2$,
- Hessian clipping bound $h^* = 0.2$,
- subsampling rate $\gamma = 0.2$,
- leaf regularization $\lambda = 15$,
- leaf regularization mode `ADD`,
- *enabled* cyclical feature interaction,
- *enabled* ignoring the split constraints,
- *enabled* random splits from candidates,
- *disabled* split refinement,
- *enabled* initial score solely for regression datasets, and
- initial score clipping bound $m^* = 0.5$.

For comparability on the three comparison datasets, we reuse S-BDT's attribute and regression value ranges: for *Abalone*, the regression value range is the actual min-max values and the attribute range is $0 \dots 0.5$; for *Adult* $0 \dots 100$; and for *Spambase* $0 \dots 1$.

C.3. Adaptive Number of Trees

In Figures 8 and 9 we show how the actual number of trees of all three S-BDT variants changes throughout the training (cf. Section 7.2 for the interpretation).

C.4. Ablation on (Maximal) Number of Trees T

We show in Figures 11 and 12 how the privacy-utility tradeoff of early-stopped and non-HP-tuned S-BDT changes when we use a more or less sophisticated initial guess of the (maximal) number of trees T. If we select a small number of trees $T = 60$, both variants of S-BDT improve in the lower ε regime but worsen in the higher ε regime. If we select a high number of trees $T = 6{,}000$, then non-HP-tuned S-BDT worsens in the lower ε regime but improves in the higher ε regime. In comparison, early-stopped S-BDT has an RMSE/AUC roughly on par with non-HP-tuned S-BDT for a small $T = 60$ except for *Abalone*, where the early-stopped S-BDT is better. However, early-stopped S-BDT has a significantly better RMSE/AUC for the majority of (dataset-ε)-combinations with a growing number of trees starting from $T = 600$ for regression and $T = 6{,}000$ for classification. This advantage of early-stopped S-BDT is especially visible in the lower ε regime.

We chose $T = 6{,}000$ trees as a default for our early-stopped S-BDT experiments, since our experiments show that non-HP-tuned S-BDT sometimes performs better on $T = 6{,}000$ trees. As seen in Figures 11 and 12) when comparing the blue lines of the center with the one of the right column and whenever ε-values are in range, starting from roughly $\varepsilon = 4.3$ (*Insurance*), $\varepsilon = 1.1$ (*Credit*), $\varepsilon = 0.11$ (*Adult*), and $\varepsilon = 0.5$ (*Spambase*) the RMSE/AUC of non-HP-tuned S-BDT for $T = 600$ trees on par or worse with the one with $T = 6{,}000$ trees. At $\varepsilon = 10$ and $T = 6{,}000$, non-HP-tuned S-BDT has a decisively better RMSE/AUC then $T = 600$ trees: 6600 vs 7200 (*Insurance*), $84.4\,\%$ vs $85.2\,\%$ (*Credit*), $88.4\,\%$ vs $90.0\,\%$ (*Adult*), and $95.2\,\%$ vs $97.1\,\%$ (*Spambase*). Only *Abalone* falls short in the RMSE: 2.44 ($T = 600$) vs 2.48 ($T = 6{,}000$).

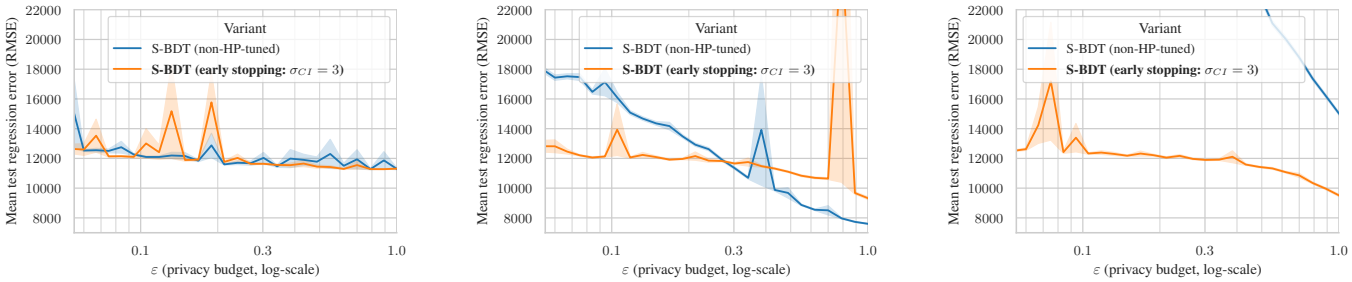
Appendix D. Rollback Protection Details

D.1. System and Adversary Model

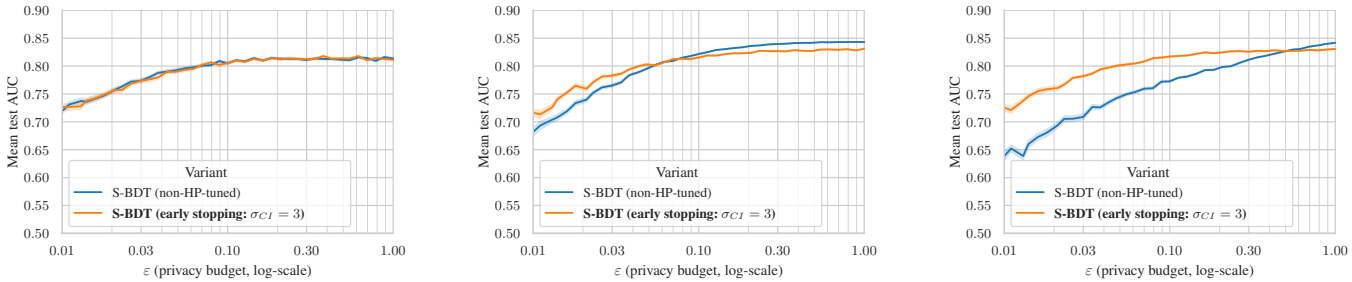
We consider the following entities shown in Figure 2 of Section 5. The DP system is hosted on an untrusted *server*. The server's administrator may be malicious, or the server's privileged software (OS, hypervisor) may be compromised. The server has a trusted execution environment (*TEE*) that provides secure execution, but may leak timing side-channel traces to the adversary. The TEE supports remote attestation that allows external entities to verify the code of the TEE application and securely send data to an attested TEE application. Intel's SGX or TDX are examples of such TEE architectures.

Data owners attest the TEE application before sending sensitive training data to it. Data owners can be either honest or malicious. Honest data owners follow the protocol to protect their data. Malicious data owners may deviate from the protocol in an attempt to violate the privacy of other data owners. We assume that at least one of the data owners is honest. If all data owners are malicious, no solution can protect the privacy of their data.

The server has a *disk* to which the TEE application can save its persistent state using the TEE's sealing functionality. We assume that sealing supports data confidentiality and authenticity, but not data freshness, which is the case in current commodity TEEs. Finally, we assume a state continuity module (*SCM*) which could be a local security chip, such as a TPM, or a distributed state-keeping system [14], [15] that is accessed over a network connection.

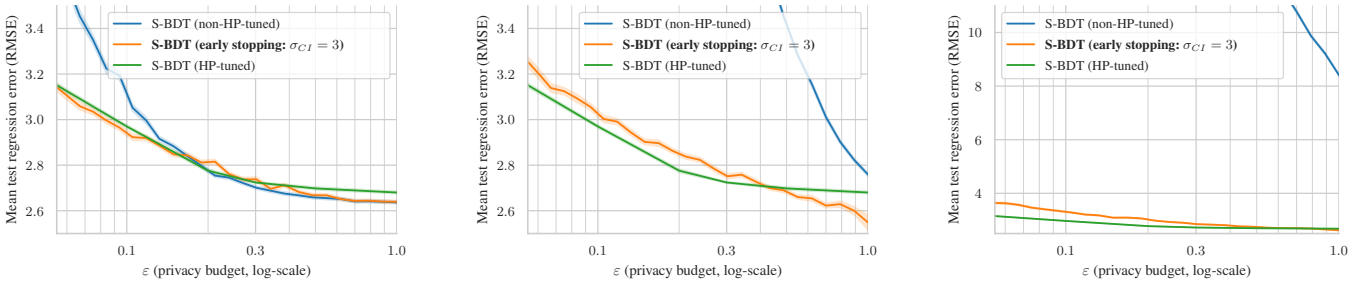


(a) Test (*Insurance*), $T = 60$ (b) Test (*Insurance*), $T = 600$ (c) Test (*Insurance*), $T = 6{,}000$

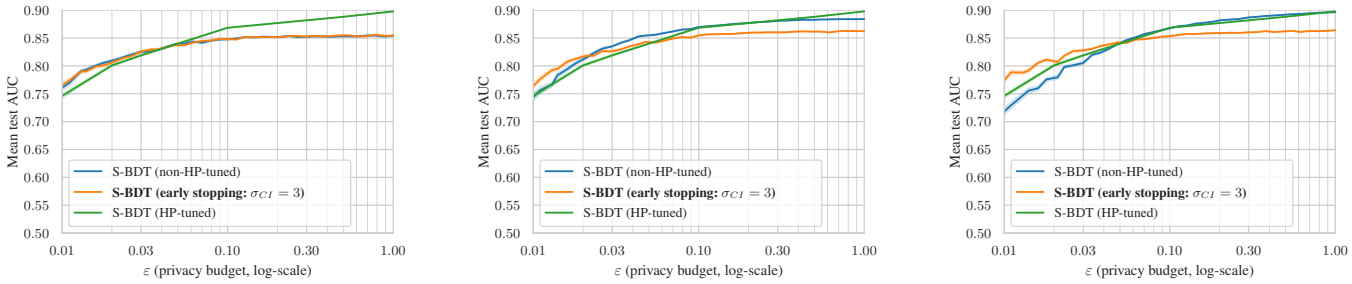


(d) Test (*Credit*), $T = 60$ (e) Test (*Credit*), $T = 600$ (f) Test (*Credit*), $T = 6{,}000$

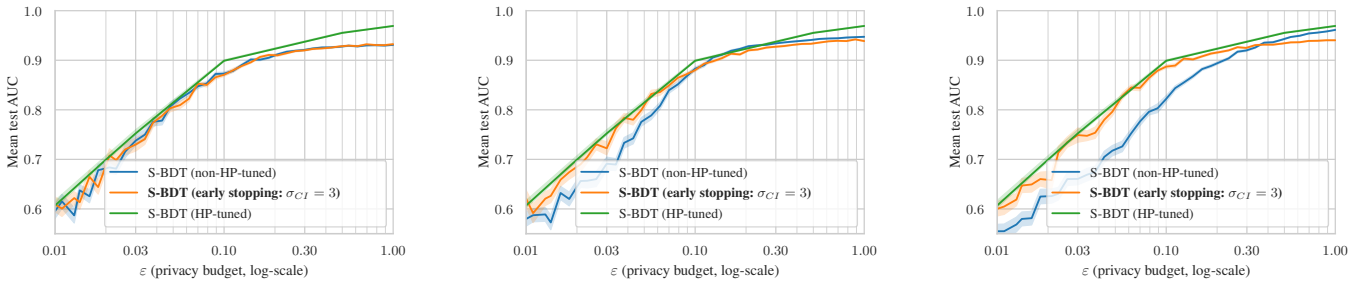
Figure 11: S-BDT on 2 test datasets: RMSE/AUC vs. (maximal) number of trees T. Top: regression; bottom: classification.



(a) Comparison (*Abalone*), $T = 60$ (b) Comparison (*Abalone*), $T = 600$ (c) Comparison (*Abalone*), $T = 6{,}000$



(d) Comparison (*Adult*), $T = 60$ (e) Comparison (*Adult*), $T = 600$ (f) Comparison (*Adult*), $T = 6{,}000$



(g) Comparison (*Spambase*), $T = 60$ (h) Comparison (*Spambase*), $T = 600$ (i) Comparison (*Spambase*), $T = 6{,}000$

Figure 12: S-BDT on 3 comparison datasets: RMSE/AUC vs. (maximal) number of trees T. Top: regression; middle/bottom: classification.

SCM interface. The SCM provides the following interface that can be used by the TEE and other entities. For example, in TPMs, this interface is available through the password-based authorization features that control access to non-volatile memory (NVRAM) indices.

- SCM.Authorize(pwd): This operation prepares the SCM for subsequent use by any entity that knows the password pwd. We assume that the TEE can call this operation without leaking the pwd to the adversary.
- ok/fail ← SCM.Write(data, pwd): This operation writes data to the SCM. If the SCM was previously authorized using pwd, the operation returns ok. Otherwise, the operation returns fail.
- data/fail ← SCM.Read(pwd): This operation returns the current content of the SCM, assuming that the SCM was previously authorized using pwd. Otherwise, this operation returns fail.

Sealing interface. We assume a sealing mechanism with the following interface. We note that in TEEs like Intel's SGX, the architecture provides sealing and unsealing calls for TEE applications. In other TEE architectures, such as Intel's TDX, the architecture only derives the sealing key for the protected VM, which must then implement encryption and authentication of data itself.

- TEE.Seal(ID, data): This operation stores data identified by ID to disk using authenticated encryption based on a key provided by the TEE architecture.
- data/fail ← TEE.Unseal(ID): This operation reads, decrypts, and authenticates sealed data identified by ID from disk. If authentication succeeds, the operation returns the decrypted data. Otherwise, this operation returns fail.

Adversary model. We consider a privileged adversary that controls the untrusted server. The adversary can start and stop the TEE execution freely. During the TEE execution, the adversary can collect timing side-channel traces. The adversary cannot break the TEE's execution integrity or directly access any secret data processed inside the TEE. Neither can the adversary break the remote attestation.

The adversary has full access to the disk and can read and modify any data stored on it. When the TEE application calls TEE.Unseal, the adversary can freely choose which previously sealed data it will give to the TEE that will then decrypt and authenticate it. The adversary can also call all SCM operations through its interface. However, the adversary cannot directly manipulate the contents of the SCM beyond what the interface allows.

D.2. Rollback Protection Algorithms

We define two simple data structures. The first is a hash chain called $\mathsf{history}_n = \mathsf{hash}(\mathsf{history}_{n-1} \parallel \mathsf{data}_n)$ that is extended by concatenating the new data element to the previous chain value and then hashing the result. The second data structure is a tuple state = {model, budget, seed, pwd, history} that encodes the TEE implementation's persistent state, which includes the trained ML model model, the privacy budget budget, a randomness seed seed, an authorization password pwd, and the hash chain history that encodes the history of all execution inputs. These data structures are used by the following three algorithms.

Algorithm 7: TEE-INIT. Initializes the rollback protection system.

```
1  receive rand from data owners;
2  randomness ← XOR each rand;
3  derive seed and pwd from randomness;
4  SCM.Authorize(pwd);
5  history ← 0;
6  state ← {empty model, full budget, seed, pwd, history};
7  TEE.Seal(STATE, state);
8  SCM.Write(history, pwd);
```

Algorithm 8: TEE-MAIN. Performs ML model training.

```
1  receive data from data owners;
2  state ← TEE.Unseal(STATE) or abort;
3  history ← SCM.Read(state.pwd);
4  check (history = state.history) or abort;
5  TEE.Seal(DATA, data);
6  history ← hash(history ‖ data);
7  SCM.Write(history, state.pwd);
8  model ← train(state.model, data, state.seed);
9  update privacy budget;
10 state ← {model, budget, state.seed, state.pwd, history};
11 TEE.Seal(STATE, state);
```

TEE-Init. Algorithm 7, called TEE-Init, is used to initialize the rollback protection system. First, the TEE receives randomness shares from all data owners. To protect their data, honest data owners will send such randomness only once and refuse to do it again after they have sent training data to the TEE. The TEE algorithm combines the received randomness shares and derives two values, seed and pwd, using the combined randomness. Using the derived password, the TEE authorizes the use of the SCM. The algorithm also sets the current history to value zero and initializes the TEE's persistent state with an empty ML model, full privacy budget, the derived randomness seed and password, and an empty history as freshness tag (hash chain). Finally, the TEE seals its persistent state on disk and writes the current history value as the initial freshness tag to the SCM.

TEE-Main. Algorithm 8, TEE-Main, is used for receiving new training data and re-training the model. A similar algorithm could be used to answer model queries from analysts. The TEE first receives training data from data owners and unseals its persistent state from disk. The execution can only proceed if the history (hash chain) value included in the unsealed persistent state matches the one in the SCM. If this is the case, the operation saves the input data for possible

Algorithm 9: TEE-RECOVER. Recovers from crashes.

```
1 state ← TEE.Unseal(STATE);
2 data ← TEE.Unseal(DATA);
3 history ← SCM.Read(state.pwd);
4 check (history = hash(state.history ‖ data)) or abort;
5 model ← train(state.model, data, state.seed);
6 update privacy budget;
7 state ← {model, budget, state.seed, state.pwd, history};
8 TEE.Seal(STATE, state);
```

later use by sealing it and extends the history hash chain with the input data. The extended history chain value is written to the SCM. After that, the model can be re-trained, and the privacy budget updated. Finally, the TEE seals its current persistent state to disk.

TEE-Recover. Algorithm 9, TEE-Recover, is used for safe recovery, in case the TEE crashes during model training in TEE-Main. This operation unseals the previous state and input data, extends the history, and checks that the extended history matches the tag value in NVRAM. If this is the case, the model training and state sealing can proceed as before.

D.2.1. Implementation. We implement our rollback protection using TPM 2.0 as an SCM. Messages from the TPM are sent in an audited session where the digest of the session is then signed, and a nonce is added to ensure authenticity and freshness. For sealing of data, we utilize 256-bit AES-GCM provided by the libsodium [85] C library. For hashing, we utilize SHA256.

D.3. Security Analysis

We provide an informal reasoning why the main security guarantees, privacy budget integrity, and timing side-channel minimization, hold for our solution.

Budget integrity. Since TEEs provide execution integrity, the adversary cannot manipulate the TEE's execution directly and, for example, remove the privacy budget enforcement check. However, the adversary can freely choose which version of the sealed state it provides to the TEE upon unsealing. In addition, the adversary can attempt to manipulate the freshness tag that is stored in the SCM. To cover both cases, we split our reasoning into two parts.

Part 1: With respect to the sealed data, the adversary has five options. First, the adversary can provide the latest version of the sealed state (we call it version n) to the TEE. In this case, the TEE will accept the seal and enforce the budget check based on the correct value. Second, the adversary can provide the previous sealed state (version $n-1$). In this case, the TEE-Main routine will fail, but the TEE-Recover routine will accept the previous seal, assuming that the also sealed input data is the latest. The same DP computation will be executed again, starting from the previous budget value and resulting in the correctly updated budget value. No privacy budget re-use is possible. Third, the adversary can provide an older sealed state (version $< n-1$). In such cases, both TEE-Main and TEE-Recover will abort. Fourth, the adversary can provide no sealed state at all in an attempt to trick the TEE into believing that the system has not yet been initialized. However, in this case TEE-Init will fail, as long as at least one of the data owners is honest and does not send a randomness share again to the TEE. Fifth, the adversary can provide a fake sealed data element, with freely chosen content, that was not previously produced by the TEE. Both TEE-Main and TEE-Recover will refuse to accept such data, because the TEE.Unseal operation will return fail and the TEE will detect the manipulation and abort its execution. We conclude that none of the five options enables privacy budget reuse for the adversary.

Part 2: Regarding the SCM, the adversary has two alternatives. First, the adversary can directly call SCM.Write, but since the adversary does not know the correct authorization password, this call will fail. Second, the adversary can call SCM.Authorize with an adversary-chosen password followed by SCM.Write with the same password and adversary-chosen data. This strategy will allow the adversary to change the SCM content, but the next time the TEE will call SCM.Read, the operation will return fail (due to the changed password) and the TEE will detect manipulation and abort. Thus, neither option enables the reuse of the privacy budget.

Given *Parts 1* and *2*, we conclude that the adversary cannot reuse privacy budget, and thus budget integrity holds.

Timing Side-channel minimization. We say a rollback protection minimizes timing side-channels if the number of timing side-channel traces the adversary can collect is limited by the legitimate executions defined by the available privacy budget. The adversary can trigger DP computations using two TEE algorithms. First, the adversary can call TEE-Main, which checks the unsealed freshness tag against the SCM and writes the new freshness tag to the SCM *before* the DP computation. This approach eliminates the side-channel oracle that is present in ElephantDP, for example, and ensures that every timing side-channel trace collected through TEE-Main will extend the history (freshness tag) and update the privacy budget that is available for the next DP computation.

Second, the adversary can call TEE-Recover, which may reexecute the previous DP computation. Assuming that the hash function used in the hash chain is collision-resistant, the freshness tag check will only succeed if the previous state and the input data are the same as in the previous DP computation. Our solution ensures that the seed used to derive all pseudo-random values used in the DP computation is the same. Furthermore, our implementation hardening ensures that there is no leakage of sensitive data from arithmetic operations and similar instructions that are known to cause leakage (see Section 4). Together, these protections ensure that the only timing side-channel trace that the adversary can collect through TEE-Recover is the

same trace that the adversary already has. We conclude that the adversary cannot collect more timing side-channel traces than what is permitted by the privacy budget.

Appendix E. Timing Privacy

We prove so-called Timing Privacy [29] in an idealized RAM model to validate our construction of Algorithm 5.

Timing Privacy (cf. Theorem 6) is a framework for ensuring DP in the presence of timing side-channels. Intuitively, timing private mechanisms should not leak much more information about their input than what is already revealed by their output distribution. The formal definition is as follows.

Definition 6 (Timing Privacy, special case of Definition 31 in [29])**.** A randomized mechanism $M\colon \mathcal{X} \times \mathcal{E} \mapsto \mathcal{R} \times \mathcal{E}$ satisfies $(1 \mapsto \rho(\alpha))$-Timing Privacy if, for any two neighboring datasets $X \sim X'$, any $\text{env}, \text{env}' \in \mathcal{E}$ and any $y \in \text{supp}(\text{out}(M(X, \text{env}))) \cap \text{supp}(\text{out}(M(X', \text{env}')))$:

$$\begin{aligned} &\mathrm{D}_\alpha(T_M(X, \text{env})|_{\text{out}(M(X,\text{env}))=y} \parallel \\ &\quad T_M(X', \text{env}')|_{\text{out}(M(X',\text{env}'))=y}) \leq \rho(\alpha) \end{aligned} \tag{9}$$

where $T_M(X, \text{env})$ is the runtime of M on inputs X & runtime environment env and $\text{out}(M(X, \text{env}))$ is the output of M.

For our proof, we assume that all hyperparameters are baked into Algorithm 5 and are not part of the input. We note that the DP-approximated input length $\tilde{l}$ (cf. Algorithm 5) can be reused instead of being recomputed for the DP initial score (cf. Algorithm 12). We use the ω-bit Word RAM model's oracle `RAND` to sample uniform noise. We extend the model by oracles for selection between two values u, v based on a boolean selector b (cf. Algorithm 4), logarithm, binomial coefficient, exponentiation, Bernoulli sampling, and Gaussian sampling. We assume all oracles to perform in a single time step, but note that this assumption is met in practice by making all oracles constant-time using the libftfp [32] and FACCT [28] libraries. We also assume that the sequence of memory cells is large enough to store $\tilde{l}$ data points and that reading from uninitialized memory is safe, so we can read placeholder data points from uninitialized memory after the actual data points. We assume that one operation (e.g., calling an oracle or performing a multiplication) can be done per time step. Under these assumptions, we show the following result.

Theorem 7. *Algorithm 5 satisfies $(1 \mapsto \rho_{\text{input}}(\alpha))$-Timing Privacy.*

Proof. Let $X \sim X'$ be two neighboring datasets and $y \in \mathcal{R}$ an arbitrary output. Let T be the number of trees and d the depth of trees. Let $\tilde{l} \coloneqq |X| + \mathcal{N}(0, \sigma^2_{\text{input}}) + 2\sigma_{\text{input}}$ be the DP approximated input length of input X (cf. Algorithm 5).

By direct analysis, counting one time step per oracle call and per arithmetic operation and treating expressions that depend only on hyperparameters as precomputed, we get the amount of operations for each component of Algorithm 10: the DP initial score in Algorithm 12 ($3\tilde{l} + 12$), and, in each round $t \in \{1, \dots, T\}$: generating uniformly random splits for the random tree ($2^{d+1} - 1$), updating and filtering individual privacy budgets at a fixed RDP order ($35\tilde{l}$), Poisson subsampling in Algorithm 18 ($2\tilde{l}$), initializing the leaf arrays (2^d), ensemble prediction in Algorithm 15 for every data point ($\tilde{l}$, plus $\tilde{l} \cdot (6 \cdot 2^d - 2)$ for each of the $t-1$ previously trained trees, since the constant-time tree prediction in Algorithm 16 visits every node), computing gradients and Hessians in Algorithm 17 ($2\tilde{l}$), building the leaf bitmasks in Algorithm 11 ($\tilde{l} \cdot (4 \cdot 2^d - 3) + 2^d$), DP approximating the 2^d leaf values in Algorithm 13 ($2^d \cdot (10\tilde{l} + 7)$), and writing the tree back to memory ($2^{d+1} - 1$). Summing over all rounds and using $\sum_{t=1}^{T}(t-1) = (T^2 - T)/2$, we obtain a constant amount of operations independent of the input length

$$K = 12 + (13 \cdot 2^d - 2)\, T \tag{10}$$

and a constant amount of iterations for each data point in the input

$$k = 3 + (11 \cdot 2^d + 38)\, T + (3 \cdot 2^d - 1)\, T^2. \tag{11}$$

Let M be the mechanism of Algorithm 1 on the padded input. The runtimes yield

$$\begin{aligned} &T_M(X, \text{env})|_{\text{out}(M(X,\text{env}))=y} \\ &= \big(\mathcal{N}(|X|, \sigma^2_{\text{input}}) + 2\sigma_{\text{input}}\big) \cdot k + K \\ &= \mathcal{N}\big((|X| + 2\sigma_{\text{input}}) \cdot k + K,\ k^2\sigma^2_{\text{input}}\big) \end{aligned} \tag{12}$$

and similarly for X'. We compute the Timing Privacy guarantee of M:

$$\begin{aligned} &D_\alpha\big(T_M(X, \text{env})|_{\text{out}(M(X,\text{env}))=y} \parallel \\ &\qquad T_M(X', \text{env}')|_{\text{out}(M(X',\text{env}'))=y}\big) \\ &= D_\alpha\big(\mathcal{N}((|X| + 2\sigma_{\text{input}})k + K, k^2\sigma^2_{\text{input}}) \parallel \\ &\qquad \mathcal{N}((|X'| + 2\sigma_{\text{input}})k + K, k^2\sigma^2_{\text{input}})\big) \\ &= D_\alpha\big(\mathcal{N}(0, k^2\sigma^2_{\text{input}}) \parallel \mathcal{N}(k, k^2\sigma^2_{\text{input}})\big) \end{aligned}$$

(using [42, Proposition 7])

$$\leq \quad \frac{\alpha}{2\sigma^2_{\text{input}}} =: \rho_{\text{input}}(\alpha) \tag{13}$$

□

Appendix F.
Pseudocode for Constant-Time S-BDT

Algorithm 10: Constant-time S-BDT.

Input: T: number of rounds, D: training data

$f^{(0)} =$ `DPInitScore(...)`; // cf. Algorithm 12

$f = (f^{(0)})$; // ensemble, initiated with init score

for $t = 1$ **to** T **do** // train tree $f^{(t)}$

  $f^{(t)} =$ `RandomBinaryTree(...)`;

  $\texttt{Bitmask}_F =$ `PrivacyFilter(`D`,...)`;

  $\texttt{Bitmask}_S =$ `PoissonSubsample(`D`,...)`;

  $\forall j\colon I^{(\text{train})}_{\text{Leaf}_j} = []$; // initialize leaf array

  $\mathcal{P} =$ `PredictEnsemble(`f, D`)`; // cf. Algorithm 15

  $(g_i, h_i)_{i=1}^{|D|} =$ `ComputeGradientsHessians(`$\mathcal{P}$`,...)`;

  `MakeTree(...)`;

  for each *leaf* v_j **in** $f^{(t)}$ **do** // cf. Equation (4)

    $f_j^{(t)}(\cdot) \coloneqq$ `DPLeaf(...)`;

  Append tree $f^{(t)}$ to ensemble f;

return f;

Algorithm 11: MakeTree

Input: D: training data, v: current node, $\texttt{Bitmask}_L$: leaf bitmask

if v *is a leaf* **then**

  Store $\texttt{Bitmask}_L$ in $v.\texttt{Bitmask}_L$;

  return;

else

  Copy $\texttt{Bitmask}_L$ into $\texttt{Bitmask}_L^{\text{left}}$;

  Copy $\texttt{Bitmask}_L$ into $\texttt{Bitmask}_L^{\text{right}}$;

  for each *sample* (x_i, y_i) **in** D **do**

    $\texttt{Bitmask}_L^{\text{left}}[i] = v_i.\text{split_criterion}(x_i)$;

    $\texttt{Bitmask}_L^{\text{right}}[i] = 1 - v_i.\text{split_criterion}(x_i)$;

  `MakeTree(`$D, v.$*child.left*$, \texttt{Bitmask}_L^{left}$`)`;

  `MakeTree(`$D, v.$*child.right*$, \texttt{Bitmask}_L^{right}$`)`;

Algorithm 12: DPInitScore: Compute a DP initial score

Input: D: training dataset, m^*: clipping bound on labels

$\varepsilon_{\text{init}}$: DP privacy budget for initial score

$\varepsilon_{\text{ds}} = 0.025$: DP privacy budget for dataset size

$|D|_{\text{priv}} = 0$;

$M = 0$;

for each *sample* (x_i, y_i) **in** D **do**

  $|D|_{\text{priv}} = |D|_{\text{priv}} + 1$;

$|D|_{\text{priv}} = |D|_{\text{priv}} +$ `CTGauss(`$0, 2 \cdot \ln(1.25/\delta)/\varepsilon_{ds}^2$`)`; // constant-time Gauss

if *regression* **then**

  for each *sample* (x_i, y_i) **in** D **do**

    $M = M +$ `CTClamp(`$y_i, -m^*, m^*$`)` ;

  $M_{\text{priv}} = \frac{1}{|D|_{\text{priv}}} \cdot M +$ `CTGauss(`$0, 2\ln(1.25/\delta)(m^*/(|D|_{priv} \cdot \varepsilon_{init}))^2$`)` ;

  return M_{priv}

else if *classification* **then**

  for each *sample* (x_i, y_i) **in** D **do**

    $M = M +$ `CTClamp(`$y_i, 0, m^*$`)` ;

  $M_{\text{priv}} = \frac{1}{|D|_{\text{priv}}} \cdot M +$ `CTGauss(`$0, 2\ln(1.25/\delta)(m^*/(|D|_{priv} \cdot \varepsilon_{init}))^2$`)`; // constant-time Gauss

  return $\ln(M_{\text{priv}}/1 - M_{\text{priv}})$

Algorithm 13: DPLeaf: Compute a DP leaf node

Input: D: training data, v: leaf node
$(g \in D, h \in D)$: gradient/Hessian of data points in D
(g^*, h^*): clipping bound on gradients and Hessians
(r_1, r_2): noise weights for leaf value
λ, β: regularization parameters
σ^2_{leaf}: unweighted variance of Gaussian for leaves
$\texttt{Bitmask}_F$: privacy filter bitmask
$\texttt{Bitmask}_S$: subsample bitmask

for each *sample* (x_i, y_i) **in** D **do**
  $w = w + \texttt{CTClamp}\,(h_i, 0.0, h^*)\ \cdot v.\texttt{Bitmask}_L[i] \cdot \texttt{Bitmask}_F[i] \cdot \texttt{Bitmask}_S[i]$;
  $u = u + \texttt{CTClamp}\,(g_i, -g^*, g^*)\ \cdot v.\texttt{Bitmask}_L[i] \cdot \texttt{Bitmask}_F[i] \cdot \texttt{Bitmask}_S[i]$;
$\tilde{w} = \lambda + w + \texttt{CTGauss}\,(0.0, (h^*)^2\sigma^2_{leaf}/(2 \cdot r_1))$; // constant-time Gauss
$\tilde{u} = u + \texttt{CTGauss}\,(0.0, (g^*)^2\sigma^2_{leaf}/(2 \cdot r_2))$; // constant-time Gauss
return $\texttt{CTClamp}\,(v = \tilde{u}/\tilde{w}, -\beta, \beta)$

Algorithm 14: CTClamp: Constant-time clamp

Input: v: value to clamp, l: lower bound, r: upper bound
$v' = l \cdot (v < l) + v \cdot (v \geq l)$;
$v' = l \cdot (v' > r) + v' \cdot (v' \leq r)$;
return v';

Algorithm 15: PredictEnsemble

Input: x: data point, f: S-BDT ensemble, η: learning rate
$\hat{y} = f^{(0)}$;
for $t = 1$ **to** $\texttt{Length}\,(f) - 1$ **do**
  $v = f^{(t)}$.root;
  $\hat{y} = \hat{y} + \eta \cdot \texttt{PredictTree}\,(v, x)$;
return $\hat{y}$;

Algorithm 16: PredictTree: Compute prediction of tree

Input: v: node of tree, x: data point
if v *is leaf* **then**
  return prediction of v
l = $\texttt{PredictTree}(v.\text{child.left}, x)$
r = $\texttt{PredictTree}(v.\text{child.right}, x)$
return $v.\text{split_criterion}(x) \cdot l + (1 - v.\text{split_criterion}(x)) \cdot r$

Algorithm 17: ComputeGradientsHessians: Compute gradients and Hessians

Input: $\mathcal{P}$: ensemble prediction on D, D: data
if *regression* **then**
  for each *sample* (x_i, y_i) **in** D **do**
    $g_i = \mathcal{P}[i] - y_i$
    $h_i = 1$
else if *classification* **then**
  for each *sample* (x_i, y_i) **in** D **do**
    $g_i = 1/(1 + \exp(-\mathcal{P}[i])) - y_i$
    $h_i = (y_i + g_i) \cdot (1 - y_i - g_i)$
return $(g_i, h_i)_{i=1}^{|D|}$

Algorithm 18: PoissonSubsample: Generate subsample bitmask

Input: D: data, γ: subsampling ratio
$\texttt{Bitmask}_S = [0, ..., 0]$;
for each *sample* (x_i, y_i) **in** D **do**
  $\texttt{Bitmask}_S[i] = \texttt{CTBernoulliBit}\,()$; // constant-time Bernoulli
return $\texttt{Bitmask}_S$;